



EU Cyber Resilience Act

Companion Guide for VMware Cloud Foundation 9.1

June 2026

Table of Contents

Disclaimer.....7

Version..... 8

Introduction 8

Third Party Identifiers and Mappings 8

Coverage Levels 8

Controls..... 9

 Control 3 9

 Control 6 10

 Control 6(a) 11

 Control 6(b) 12

 Control 13.1 13

 Control 13.2 14

 Control 13.4 16

 Control 13.5 17

 Control 13.6 18

 Control 13.7 19

 Control 13.8 20

 Control 13.12 23

 Control 13.13 24

 Control 13.14 28

 Control 13.18 29

 Control 13.20 30

 Control 13.21 31

 Control 13.22 32

 Control 14.1 37

 Control 14.3 38

 Control 14.8 39

 Control 18.1 40

 Control 18.3 41

 Control 18.3(a) 42

 Control 18.3(b) 43

 Control 18.3(c) 44

 Control 19.1 45

Control 19.2	46
Control 19.2(a)	47
Control 19.2(b)	48
Control 19.2(c)	49
Control 19.3	50
Control 19.4	51
Control 19.5	52
Control 19.6	53
Control 19.7	57
Control 20.1	61
Control 20.2	62
Control 20.2(a)	63
Control 20.2(b)	64
Control 20.3	65
Control 20.4	66
Control 20.5	67
Control 31.1	71
Control 31.2	72
Control 31.3	73
Control 31.4	74
Control 32.1	75
Control 32.1(a)	77
Control 32.2(a)	79
Control 32.2(b)	81
Control Annex I Part I (1)	83
Control Annex I Part I (2)(a)	84
Control Annex I Part I (2)(b)	88
Control Annex I Part I (2)(c)	91
Control Annex I Part I (2)(d)	94
Control Annex I Part I (2)(e)	95
Control Annex I Part I (2)(f)	96
Control Annex I Part I (2)(g)	97
Control Annex I Part I (2)(h)	103
Control Annex I Part I (2)(i)	104

Control Annex I Part I (2)(j)	105
Control Annex I Part I (2)(k)	109
Control Annex I Part I (2)(l)	110
Control Annex I Part II (1)	111
Control Annex I Part II (2)	112
Control Annex I Part II (3)	115
Control Annex I Part II (4)	116
Control Annex I Part II (5)	117
Control Annex I Part II (6)	118
Control Annex I Part II (7)	119
Control Annex I Part II (8)	122
Control Annex II (1)	125
Control Annex II (2)	126
Control Annex II (3)	127
Control Annex II (4)	128
Control Annex II (5)	129
Control Annex II (6)	130
Control Annex II (7)	131
Control Annex II (8)	132
Control Annex II (8)(a)	133
Control Annex II (8)(b)	134
Control Annex II (8)(c)	135
Control Annex II (8)(d)	136
Control Annex II (9)	137
Control Annex III Class I (1)	138
Control Annex III Class I (2)	139
Control Annex III Class I (3)	140
Control Annex III Class I (4)	141
Control Annex III Class I (5)	142
Control Annex III Class I (6)	143
Control Annex III Class I (7)	144
Control Annex III Class I (8)	145
Control Annex III Class I (9)	146
Control Annex III Class I (10)	147

Control Annex III Class I (11)	148
Control Annex III Class I (12)	149
Control Annex III Class I (13)	150
Control Annex III Class I (14)	151
Control Annex III Class I (15)	152
Control Annex III Class II (1)	153
Control Annex III Class II (2)	154
Control Annex III Class II (3)	155
Control Annex IV (1)	156
Control Annex IV (2)	157
Control Annex IV (3)	158
Control Annex V	159
Control Annex V (1)	160
Control Annex V (2)	161
Control Annex V (3)	162
Control Annex V (4)	163
Control Annex V (5)	164
Control Annex V (6)	165
Control Annex V (7)	166
Control Annex V (8)	167
Control Annex VII	168
Control Annex VII (1)	169
Control Annex VII (1)(a)	170
Control Annex VII (1)(b)	171
Control Annex VII (1)(c)	172
Control Annex VII (1)(d)	173
Control Annex VII (2)	174
Control Annex VII (2)(a)	175
Control Annex VII (2)(b)	176
Control Annex VII (2)(c)	177
Control Annex VII (3)	178
Control Annex VII (5)	179
Control Annex VII (6)	180
Control Annex VII (7)	181

Control Annex VII (8)	182
Control Annex VIII Part I (1)	183
Control Annex VIII Part I (2)	185
Control Annex VIII Part I (3)	186
Control Annex VIII Part I (5)	187
Control Annex VIII Part II (4.1)	188
Control Annex VIII Part II (10)	189
Control Annex VIII Part III (2)	193
Control Annex VIII Part III (3)	194
Control Annex VIII Part III (3.1)	195
Control Annex VIII Part III (3.2)	196
Control Annex VIII Part III (4)	197
Control Annex VIII Part IV (2)	198
Control Annex VIII Part IV (3.1)	199
Control Annex VIII Part IV (3.4)	200
Control Annex VIII Part IV (3.5)	201
Control Annex VIII Part IV (4.2)	202
Control Annex VIII Part IV (5.1)	206
Control Annex VIII Part IV (5.2)	207
Control Annex VIII Part IV (6)	208

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260612-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward compliance with the Cyber Resilience Act (CRA), formally Regulation (EU) 2024/2847. The CRA establishes horizontal cybersecurity requirements for products with digital elements, covering essential cybersecurity and vulnerability-handling requirements, manufacturer, importer, and distributor obligations, reporting of actively exploited vulnerabilities and severe incidents, and conformity assessment. The SCF 2026.1 crosswalk was mapped against the 2022 Commission proposal; the control identifiers in this guide use the adopted regulation's numbering, with each mapping verified against both texts. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for assessing and achieving compliance with the CRA remains with the manufacturer or other economic operator.

<https://eur-lex.europa.eu/eli/reg/2024/2847/oj>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control 3

> Definitions: For the purposes of this Regulation, the following definitions apply:

SCF Controls: SEA-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6

> Requirements for products with digital elements: Products with digital elements shall be made available on the market only where:

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6(a)

> they meet the essential cybersecurity requirements set out in Part I of Annex I, provided that they are properly installed, maintained, used for their intended purpose or under conditions which can reasonably be foreseen, and, where applicable, the necessary security updates have been installed; and

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6(b)

> the processes put in place by the manufacturer comply with the essential cybersecurity requirements set out in Part II of Annex I.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.1

> When placing a product with digital elements on the market, manufacturers shall ensure that it has been designed, developed and produced in accordance with the essential cybersecurity requirements set out in Part I of Annex I.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.2

> For the purpose of complying with paragraph 1, manufacturers shall undertake an assessment of the cybersecurity risks associated with a product with digital elements and take the outcome of that assessment into account during the planning, design, development, production, delivery and maintenance phases of the product with digital elements with a view to minimising cybersecurity risks, preventing incidents and minimising their impact, including in relation to the health and safety of users.

SCF Controls: CPL-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The Badge|Compliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual

obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.4

> When placing a product with digital elements on the market, the manufacturer shall include the cybersecurity risk assessment referred to in paragraph 3 of this Article in the technical documentation required pursuant to Article 31 and Annex VII. For products with digital elements as referred to in Article 12, which are also subject to other Union legal acts, the cybersecurity risk assessment may be part of the risk assessment required by those Union legal acts. Where certain essential cybersecurity requirements are not applicable to the product with digital elements, the manufacturer shall include a clear justification to that effect in that technical documentation.

SCF Controls: TDA-22.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.5

> For the purpose of complying with paragraph 1, manufacturers shall exercise due diligence when integrating components sourced from third parties so that those components do not compromise the cybersecurity of the product with digital elements, including when integrating components of free and open-source software that have not been made available on the market in the course of a commercial activity.

SCF Controls: TPM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.6

> Manufacturers shall, upon identifying a vulnerability in a component, including in an open source-component, which is integrated in the product with digital elements report the vulnerability to the person or entity manufacturing or maintaining the component, and address and remediate the vulnerability in accordance with the vulnerability handling requirements set out in Part II of Annex I. Where manufacturers have developed a software or hardware modification to address the vulnerability in that component, they shall share the relevant code or documentation with the person or entity manufacturing or maintaining the component, where appropriate in a machine-readable format.

SCF Controls: TDA-02.11, TDA-04.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.7

> The manufacturers shall systematically document, in a manner that is proportionate to the nature and the cybersecurity risks, relevant cybersecurity aspects concerning the products with digital elements, including vulnerabilities of which they become aware and any relevant information provided by third parties, and shall, where applicable, update the cybersecurity risk assessment of the products.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.8

> Manufacturers shall ensure, when placing a product with digital elements on the market, and for the support period, that vulnerabilities of that product, including its components, are handled effectively and in accordance with the essential cybersecurity requirements set out in Part II of Annex I.

SCF Controls: TDA-01.1, TDA-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides structured update delivery mechanisms and notification capabilities that support ongoing product security for its infrastructure components, though full automatic update delivery and proactive notification to all affected users require additional organizational processes.

VCF uses a tiered release model for delivering security fixes. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations and can be applied selectively to individual components without requiring synchronized updates across the entire VCF stack. These patch releases are issued between major, minor, and maintenance releases to address urgent security concerns. Maintenance releases are scheduled, cumulative updates that include bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. For VMware ESX hosts specifically, software updates including patches of the ESX base image, partner add-ons, IOVP drivers, and VMware Tools updates are available through online depots. For deployments without direct internet access, the vSphere Lifecycle Manager's Update Manager Download Service (UMDS) can be configured to download patch binaries, patch metadata, and host notifications to a local repository and serve them as an offline update source.

VCF Operations provides lifecycle management capabilities that orchestrate the update process across VCF components, including ESX hosts, vCenter, and NSX. The lifecycle management workflow handles dependency ordering, pre-upgrade validation, and coordinated rollout so that security patches are applied consistently across the infrastructure. VCF Operations requires a precheck to succeed before scheduling component upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. However, updates are not applied automatically. An administrator must review available updates and initiate the update workflow.

For the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support a rolling update model for delivering security updates to cluster infrastructure. Updates are initiated by modifying the cluster specification, with VKS Controller updates encompassing supporting services such as the Container Networking Interface (CNI), Container Storage Interface (CSI), and Cloud Provider Interface (CPI) alongside configuration updates for the clusters themselves. This rolling update mechanism allows security patches to reach cluster infrastructure components in a controlled sequence without requiring full cluster downtime. At the workload level, Kubernetes Deployments support rolling updates that replace Pod instances incrementally, so security-patched container images can be deployed without interrupting running services. VCF Automation makes update and patch actions available to consumers through its self-service catalog, where day-2 actions including updates and patches can be initiated by the workload owner independently. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS releases, providing hardening guidance and defining baseline security configurations that inform operators of recommended configuration states.

The vCenter Patching API provides programmatic access to list available updates, run pre-check validations, and stage downloads. vCenter categorizes available updates with type labels including SECURITY and BUG FIX AND SECURITY, which administrators can use when reviewing available updates to prioritize security-specific patches. PowerCLI provides a Test-Compliance command that scans hosts and clusters against downloaded patches to identify what needs remediation. These tools allow administrators to integrate patch status checks into their operational workflows.

VCF includes several notification and detection mechanisms for security updates. VCF Operations components receive security-related updates in the form of VMware Security Advisories (VMSAs), which are the primary notification mechanism for available security patches. Emergency updates are released for VCF Operations integrations in response to system

degradation issues or security bulletins. VCF Operations provides advance notice of urgent interoperability and security updates at 72-hour and 24-hour intervals before the update becomes available. VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack by cross-referencing the installed versions against published VMSAs, surfacing the exposure with a description, root cause insight, and actionable remediation steps.

For container workloads on VKS clusters, Harbor Registry, available as a Supervisor Service, provides vulnerability scanning of stored container images and content trust controls to restrict the use of unscanned or untrusted images. This gives operators visibility into images that carry known vulnerabilities, informing decisions about which images require patching or replacement. The Prometheus standard package, installable on VKS clusters, deploys Prometheus and Alertmanager in the `tanzu-system-monitoring` namespace. Alertmanager receives alerts from Prometheus via HTTP and routes them to external notification channels including email and webhooks, supporting organizational workflows for notifying teams of conditions related to cluster health or component version thresholds. The AlertmanagerConfig custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external systems. For GitOps-driven environments, the ArgoCD Supervisor Service supports a notification controller that can be enabled via the `notification.enabled` configuration setting, allowing operators to receive alerts when application sync states change or when cluster state drifts from the desired configuration defined in a repository.

VCF also includes configurable notification capabilities that administrators can use for operational awareness. VMware vCenter can send email notifications and SNMP traps when alarms are triggered, with configurable recipient addresses. VCF Operations supports outbound SNMP trap notifications to external management systems, with up to four configurable trap destinations. While these notification mechanisms are designed for operational alerting rather than update notification specifically, they form part of the broader monitoring infrastructure that administrators use to maintain awareness of environment status.

These capabilities cover VCF infrastructure components and the Kubernetes consumption layer rather than all technology assets in the environment. Patching guest workloads and applications running on VCF, and maintaining container images with current security patches, remain the responsibility of the workload owners. The organization is responsible for subscribing to VMware Security Advisories, monitoring for new patches, evaluating applicability, and scheduling update windows according to change management processes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports update delivery through a configurable Maintenance Policy and an integrated upgrade management interface. The Maintenance Policy, set from the vSphere Client by a vSphere Administrator, allows administrators to schedule automatic software updates for DSM appliances and define the duration window during which updates are applied. Administrators configure a future date and time for the policy, giving organizations control over when DSM platform components are updated while reducing the manual coordination required to keep the platform current. When automatic plug-in updates fail, DSM recommends manual software updates of appliances as a fallback path.

DSM provides update discovery through a "Check for Upgrade" function, accessible in the Version & Upgrade section of the DSM UI via the DSM System tab. This function queries for available updates and displays them in the Available Upgrades table. Update bundles can be uploaded from a remote server URL with credentials or from a local file, giving administrators flexibility in sourcing release packages. Updates follow a staged progression: after a release bundle is uploaded, it transitions to a Ready to Install state before being applied during the configured maintenance window. The Version & Upgrade management interface allows administrators to track plug-in versions, release dates, and activation states.

DSM extends automatic upgrade coverage to managed databases. Administrators and users can activate automatic database upgrades by specifying a maintenance window for each data service. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, providing a mechanism for applying security-relevant patches to database instances on a defined schedule.

DSM adds SQL Server as a supported managed database type. SQL Server instances in DSM follow the Cumulative Update (CU) branch, which contains the complete set of functional, performance, and security updates for the major version, keeping SQL Server databases provisioned through DSM current with security-relevant patches as part of the standard update track.

DSM supports webhook notifications that can route system alerts to external destinations such as email, Slack channels, or ServiceNow. While these notification capabilities address operational events rather than dedicated security update announcements, they provide notification infrastructure that organizations can incorporate into update communication workflows.

Applying DSM plug-in updates requires administrators to upload release bundles and configure Maintenance Policies before automatic updates can apply. DSM does not natively send proactive notifications about available security updates to all affected users; that communication step depends on organizational processes outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) 9.1 supports security update notification through its event alerting framework and delivers automatic updates for certificate material and live security threat intelligence content.

The Avi Controller includes a configurable event alerting framework supporting four notification destinations: the local UI (displayed as colored bell icons), email, syslog, and SNMP v2c and SNMPv3 traps. Notification profiles are configured in the Operations > Notifications page. Alert configurations trigger on system events and route to one or more destinations, and can carry security-relevant notifications including conditions that signal a need for patching. SNMP notification transport can be configured with TLS encryption and strict certificate verification enabled.

For certificate-based security material, the Controller applies automatic updates. When a certificate held by the Avi Controller is updated through manual replacement, Let's Encrypt integration, or Venafi Trust Protection Platform integration, the updated certificate is automatically and transparently pushed to all Service Engines using that certificate. This propagation occurs without service interruption and without requiring separate operator action on each Service Engine. The Venafi Onboard Discovery feature automates importing certificates into Trust Protection Platform, where they can be monitored, validated, and provisioned, and Trust Protection Platform automatically handles certificate and chain certificate renewals based on the mapping of virtual service names to certificates.

Avi also introduces Live Security Threat Intelligence through the Avi Cloud Console, which provides automatic synchronization of security content to enabled deployments. The Application Rules service provides automatic synchronization of the Application Rules Database, delivering current application vulnerability protection rules without manual action. The Bot Management service includes a User Agent Database Sync capability that receives current User-Agent updates for threat detection. The IP Reputation service maintains a real-time, up-to-date security posture across globally distributed Avi Controller clusters by delivering current threat feed data automatically.

Avi WAF Enterprise license customers receive OWASP Core Rule Set (CRS) updates through the customer portal. These updates are available for download and are applied by administrators.

Software upgrade and patch operations for the Controller and Service Engine groups are administrator-initiated. During the term of a purchased subscription, customers have access to new software releases including software patches published by Broadcom for Avi Load Balancer and 24/7 support. The /api/upgrade REST API endpoint supports applying a base image, a Controller patch, and a Service Engine patch in a single operation. Upgrade, patch upgrade, rollback, and rollback patch operations are all supported. Virtual service disruption must be assessed and communicated before upgrade operations. In VCF deployments, Avi Management Plane alarms, alerts, and dashboards must be verified as operational as part of post-upgrade validation.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.12

> Before placing a product with digital elements on the market, manufacturers shall draw up the technical documentation referred to in Article 31.

SCF Controls: CPL-01.4, TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.13

> Manufacturers shall keep the technical documentation and the EU declaration of conformity at the disposal of the market surveillance authorities for at least 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer.

SCF Controls: DCH-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable data retention controls within VCF Operations that allow administrators to align operational data retention periods with organizational requirements. These controls do not address the full scope of media and data retention governance, but they give administrators granular tuning over how long different categories of platform-generated data are kept.

VCF Operations exposes data retention settings through Administration > Global Settings > Data Retention. Administrators can configure retention periods independently for several data categories. Metrics data supports a retention window between 1 month and 13 months. Entities and configuration data can be retained for a minimum of 1 month and a maximum of 3 months. Organization reports support a maximum data retention period of 1,440 days. At the normal retention tier, VCF Operations retains data at 5-minute granularity for 6 months, then rolls up the seventh month into 1-hour aggregations. A real-time retention tier provides 5-minute granularity, a standard tier retains data for 1 month, and a long-term tier retains data for 13 months. Different data retention policies can be configured and controlled for each category according to organizational requirements. Log data is governed separately through VCF Log Management, where administrators define log partitions that each carry their own retention period in days, with logs removed from disk automatically once a partition's period elapses and the option to archive partitions to external NFS or S3 storage for longer-term preservation.

VCF Operations for Networks provides additional granular retention controls. The default data retention period is 1 month in the advanced license edition. Flow data retention is fixed at a 1-month window within the platform. For organizations that need to retain flow data beyond one month, the Streaming Databus provides a mechanism to export flows to an external subscriber via HTTPS/HTTP for extended retention. Miscellaneous data retention can be configured with up to 100 GB of additional disk space.

VCF Operations also provides backup capabilities that support regulatory and operational retention needs. Administrators can take regular backups of both custom and out-of-the-box content. When reducing an entity metrics retention period in VCF Operations for Networks, the recommendation is to back up log files first to prevent data loss, which supports the principle of preserving data before modifying retention windows.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds Kubernetes-native persistent storage lifecycle controls relevant to data retention for containerized workloads. Persistent volumes in Supervisor namespaces store application data outside the lifecycle of individual pods and workloads, so data remains available when workloads restart or scale. The central mechanism governing retention behavior is the PersistentVolume reclaim policy, which controls what happens to the underlying storage and its data when the associated PersistentVolumeClaim is deleted. The Retain policy preserves the volume and its data in a Released state for manual administrator reclamation, leaving the data intact for inspection, archival, or transfer before final disposal. The Delete policy causes the storage asset to be removed when the claim is released. Retain is the default for manually provisioned PersistentVolumes. StorageClass definitions carry a ReclaimPolicy field that sets the default behavior for all dynamically provisioned volumes within a given storage class, allowing cluster administrators to enforce organization-wide retention defaults at the storage class level rather than per-volume. For StatefulSet workloads, Kubernetes provides a persistentVolumeClaimRetentionPolicy setting with a whenDeleted field that controls whether PVCs and their backing volumes are retained or deleted when the StatefulSet is removed; scaling a StatefulSet down does not delete the associated volumes by default. Organizations subject to retention obligations should configure StorageClasses with the Retain policy so that workload termination does not destroy data that must be kept for a defined period.

Storage Policy Based Management (SPBM) provides a unified control plane across VKS storage, enabling storage policies to be associated with persistent volumes that capture the storage characteristics required by a given workload or retention regime. VKS clusters surface a storage compliance status per volume: a Compliant status indicates that the datastore backing the volume satisfies the requirements of the associated policy; an Out of Date status indicates the policy has been updated but the new requirements have not yet been communicated to the datastore, requiring the policy to be reapplied to bring the volume back into compliance. This policy-driven model allows administrators to codify storage requirements and verify adherence continuously.

For Harbor Registry deployments on VKS clusters, administrators should note that configuring a StorageClass or PersistentVolume with a Delete reclaim policy results in all Harbor data being deleted when the Harbor package is removed. Image artifact retention requirements should drive reclaim policy selection for Harbor-backing storage. Platform teams should also manage data protection storage locations in VCF Automation to align with company-specific data residency and infrastructure standards.

These retention controls apply to the operational, monitoring, and configuration data that VCF Operations collects and manages, and to the persistent volume lifecycle for containerized workloads on VKS. They do not extend to application data stored within virtual machines outside the Kubernetes layer, user-generated content on datastores not managed by Kubernetes, or media outside the VCF platform. Organizations must establish broader data retention policies, classification schemes, and lifecycle management processes that address all media and data types subject to statutory, regulatory, and contractual obligations. VCF's retention settings are one component of a larger retention program that requires organizational governance, legal review of applicable obligations, and potentially additional tools for archival and disposition of data beyond what VCF Operations and VKS storage lifecycle controls manage.

VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 13.14

> Manufacturers shall ensure that procedures are in place for products with digital elements that are part of a series of production to remain in conformity with this Regulation. Manufacturers shall adequately take into account changes in the development and production process or in the design or characteristics of the product with digital elements and changes in the harmonised standards, European cybersecurity certification schemes or common specifications as referred to in Article 27 by reference to which the conformity of the product with digital elements is declared or by application of which its conformity is verified.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.18

> Manufacturers shall ensure that products with digital elements are accompanied by the information and instructions to the user set out in Annex II, in paper or electronic form. Such information and instructions shall be provided in a language which can be easily understood by users and market surveillance authorities. They shall be clear, understandable, intelligible and legible. They shall allow for the secure installation, operation and use of products with digital elements. Manufacturers shall keep the information and instructions to the user set out in Annex II at the disposal of users and market surveillance authorities for at least 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer. Where such information and instructions are provided online, manufacturers shall ensure that they are accessible, user-friendly and available online for at least 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.20

> Manufacturers shall either provide a copy of the EU declaration of conformity or a simplified EU declaration of conformity with the product with digital elements. Where a simplified EU declaration of conformity is provided, it shall contain the exact internet address at which the full EU declaration of conformity can be accessed.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.21

> From the placing on the market and for the support period, manufacturers who know or have reason to believe that the product with digital elements or the processes put in place by the manufacturer are not in conformity with the essential cybersecurity requirements set out in Annex I shall immediately take the corrective measures necessary to bring that product with digital elements or the manufacturer's processes into conformity, or to withdraw or recall the product, as appropriate.

SCF Controls: CPL-02.3, TDA-21

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 13.22

> Manufacturers shall, upon a reasoned request from a market surveillance authority, provide that authority, in a language which can be easily understood by that authority, with all the information and documentation, in paper or electronic form, necessary to demonstrate the conformity of the product with digital elements and of the processes put in place by the manufacturer with the essential cybersecurity requirements set out in Annex I. Manufacturers shall cooperate with that authority, at its request, on any measures taken to eliminate the cybersecurity risks posed by the product with digital elements which they have placed on the market.

SCF Controls: CPL-01.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to an organization's ability to demonstrate conformity with applicable cybersecurity and data protection requirements by providing built-in compliance measurement, scoring, reporting, and audit logging capabilities. The organizational processes for identifying applicable laws, regulations, and contractual obligations, and for managing the overall compliance program, fall outside the product's scope.

VCF Operations includes a Compliance capability that surfaces core aspects of VCF security configuration in a single view. This capability continuously monitors whether objects in the environment meet industrial, governmental, regulatory, or internal standards, and calculates a compliance score as the ratio of compliant objects to the total number of objects assessed by a given benchmark, displayed as a percentage. When all objects are compliant, the score card displays 100. When objects are non-compliant, the number of non-compliant symptoms is shown in red alongside the total symptom count. The compliance score for an individual object is based on the most critical of the violated standards, and the score is calculated for all objects in the environment regardless of whether a given user has visibility into every object. This means the compliance posture reported reflects the true state of the environment, not a filtered view.

The compliance engine detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules, giving administrators clear evidence of where the environment stands against a given benchmark. VCF supports compliance measurement against multiple industry-standard security guidelines and benchmarks, including the DISA STIG. NSX also provides a compliance report that administrators can use to verify that the NSX networking environment adheres to organizational IT policies and industry standards.

On the audit trail side, VCF components generate detailed logs of security-relevant events. Audit logs capture actions from the API, the user interface, and the CLI. Changes to user role assignments are automatically written to syslog and the audit log. VCF supports syslog forwarding to external monitoring systems for centralized log retention and long-term evidence preservation. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries for common compliance use cases such as failed login tracking, privilege escalation monitoring, and policy violation detection. Together, these logging and reporting capabilities allow organizations to produce and retain the technical evidence needed when demonstrating conformity to auditors or regulatory bodies.

For workloads running within VMware Kubernetes Service (VKS) on the VCF platform, the Consumption layer contributes a set of policy enforcement and access control mechanisms that produce inspectable, auditable artifacts. Pod Security Admission enforces Pod Security Standards at the namespace level with three profiles: Privileged, Baseline, and Restricted. Each namespace can be independently configured with enforce, audit, and warn modes; when a namespace runs in audit mode, the Kubernetes API server records policy violations without blocking workloads, generating per-namespace records of how running pods compare to the configured security profile. This output can be presented as direct evidence that the environment evaluates workload security posture against a defined standard. For high-assurance environments, cryptographic protections can be applied to Kubernetes audit logs to make them tamper-evident and confidential. Kubernetes Role-Based Access Control stores Roles, ClusterRoles, RoleBindings, ClusterRoleBindings, and ServiceAccounts as standard API objects, making the current permission model fully inspectable and exportable at any point; IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege. ValidatingAdmissionPolicy resources define

enforcement rules as versioned Kubernetes API objects that can be queried, compared across revisions, and archived as policy compliance snapshots, providing a mechanism for capturing what policy was in effect at a given point in time. Network policies govern ingress and egress traffic at the namespace level as declarative Kubernetes objects, constituting auditable documentation of the implemented network segmentation model. Access to download and manage VKS Cluster Management Security Policy templates requires assignment to the Organization Administrator or Organization Auditor role, maintaining separation between those who define policy and those who audit it. VCF Automation security policies apply constraints at the organization or project level, and those constraints are inherited by all child resources.

To support resilience conformity, VMware vCenter and VCF Operations each support both file-based and image-based backup and restore. The vCenter backup schedule can be configured with backup location, recurrence, and retention parameters, providing administrators with a mechanism to document that scheduled, recoverable backups of the platform management layer are in operation. VKS cluster management supports backup and restore of an entire cluster, selected namespaces, or specific resources identified by a label. These operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection, where backups can also be restored from a source cluster to a target cluster. VKS Supervisor state backup, including cluster node virtual machines, is activated through the vCenter backup feature in the vCenter Management Interface. For workload-level backup, Velero with the vSphere Plugin Snapshot or File System Backup method supports backup and restore of both stateless and stateful VKS cluster workloads; backup repositories support deduplication, compression, and encryption to protect backup integrity, and scheduled backup operations are available to support a regular recovery cadence. Organizations should maintain an etcd backup plan as part of demonstrating that cluster-state resilience capability exists.

Demonstrating conformity with cybersecurity and data protection obligations is fundamentally an organizational responsibility. VCF's compliance scoring, alerting, and reporting capabilities provide a significant portion of the technical evidence needed, but the organization must maintain the broader compliance program, including policy documentation, control mapping to applicable regulations, periodic assessments, and remediation tracking. Additional tools or processes outside VCF are needed to cover areas such as personnel security, physical security, and governance that fall outside the scope of infrastructure platform controls.

VMware Private AI Services (PAIS), formerly Private AI Services, provides several mechanisms that generate evidence relevant to demonstrating security and compliance conformity for AI infrastructure. Organizations can draw on these mechanisms when preparing documentation or responding to audits.

The PAISConfiguration custom resource includes an observability section that activates Prometheus-based metrics collection from PAIS components. Administrators activate metrics collection by uncommenting the `spec.observability.prometheusRuntime` section of the PAISConfiguration CR. Observability is configured as part of PAIS activation in VCF Automation and must be verified as active in the PAIS instance namespace. Once activated, PAIS controller pod metrics can be sent to VCF Operations through a Telegraf agent running on the Supervisor instance, and metrics can also be visualized in third-party observability platforms such as Grafana. A single Grafana instance can visualize metrics from multiple PAIS instances when they share an OIDC provider, supporting consolidated operational evidence across deployments.

PAIS observability also supports sending LLM traces to an OpenTelemetry Collector, providing a record of model inference activity within the platform. When activated, this trace data together with the Prometheus metrics gives MLOps engineers and auditors operational evidence of AI workload behavior.

PAIS uses Harbor Registry as its model artifact store, with the Model Gallery integrated to Harbor for model storage and retrieval. Harbor project access capabilities restrict access to sensitive training data and model artifacts, and Harbor robot accounts are configured for image pulls when the registry requires authentication. MLOps engineers validate ML models onboarded to PAIS against the security, privacy, and technical requirements of the organization, and PAIS guidance directs users to distribute models validated on deep learning VMs rather than models retrieved directly from the Internet. These workflows produce records of which models entered the gallery and under what governance.

Identity and access management for PAIS is coordinated with an external OIDC provider, including for Grafana integration. Within the platform, PAIS must be activated in organization namespaces by an organization administrator or MLOps engineer after namespace creation, establishing a documented authorization layer over GPU-accelerated workloads. VCF Automation Provider Management also requires trusted certificate import for vCenter certificate validation before integration with PAIS, supporting a documented trust layer. PAIS additionally requires examination and approval of MCP server tools and capabilities before use in agents, creating a review record for specialized data and capability integrations.

Demonstrating conformity with applicable laws and regulations requires more than technical controls alone. The organization must define its compliance scope, identify applicable obligations, map platform capabilities to control requirements, and assemble evidence packages for auditors or regulators. PAIS's observability, model governance, access control, and identity integration mechanisms contribute to that evidence base but do not replace the organizational governance layer that frames and presents the evidence.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend) contributes to demonstrating conformity with cybersecurity obligations by providing auditable records of security policy configuration and enforcement.

The Security Services Platform's Rule Analysis feature detects contradictions and redundancies in firewall policy by comparing effective group memberships and policy paths, allowing organizations to verify that implemented rules align with documented security requirements. Rule Analysis results can be reviewed in the Security Services Platform UI under System > Platform & Features, and the feature produces CSV reports for inclusion in compliance evidence packages. Rule Analysis access is governed by role-based permissions across five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector.

Security Intelligence policy recommendations can be generated for environments and published as firewall policies applied to environment category pairs. These recommendations include security policies and security groups, creating a documented record of recommended and enforced controls that can be presented during audits.

Role-based access controls include dedicated Auditor, Security Engineer, Security Operator, Enterprise Admin, and Support Bundle Collector roles with differentiated permissions that support segregation of duties during compliance assessments. The Auditor role provides read-only visibility into security configurations and activity, enabling independent review by compliance personnel without modification access. Privileged labels in the Distributed Firewall anchor firewall rules to immutable labels, providing a tamper-proof mechanism that helps administrators demonstrate workloads remain within their designated security groups as intended by policy.

These capabilities help produce demonstrable evidence of security control implementation. Full conformity with legal and contractual obligations also depends on organizational governance, documentation practices, and audit workflows that extend beyond what vDefend provides directly.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates technical artifacts and supports compliance-oriented subscription tiers that organizations can use as evidence when demonstrating conformity with disaster recovery and data protection requirements. PNR does not include a dedicated compliance management engine, framework mapping capability, or benchmark scoring system.

The Advanced Cyber Compliance subscription, sold as a VCF advanced service, provides on-premises data protection and recovery capabilities designed for regulated environments. Advanced cyber protection and recovery capabilities within PNR require an Advanced Cyber Compliance per-core license in addition to VCF core capabilities, and an Advanced Cyber Compliance subscription is required to configure remote snapshots. The existence of this compliance-tier subscription reflects PNR's intended use in environments subject to regulatory and contractual data protection obligations.

Protection groups and recovery plans constitute documented configurations that must be verified for connection and validity. These configurations identify which workloads are protected and the recovery objectives assigned to each workload.

Maintaining verified protection groups and recovery plans produces artifacts that organizations can present to demonstrate that DR procedures are defined and operational.

The Clean Room Orchestrator generates Events representing observations and issues raised by the system, providing information about situations that require attention or action. This event stream contributes to the operational audit record for recovery environment activities.

Identifying which laws and regulations apply, mapping controls to requirements, and managing the overall compliance program are organizational responsibilities outside the scope of PNR.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to an organization's ability to demonstrate conformity through several mechanisms: enforceable data service policies, per-policy compliance reporting, infrastructure policy guardrails with compliance alerting, configurable backup and retention controls, and audit event logging.

DSM supports the creation and enforcement of data service policies that define organizational standards for database deployments, including PostgreSQL, MySQL, SQL Server, and MinIO databases. Administrators configure these policies and assign them to one or more organizations or tenants, creating a documented, repeatable configuration baseline. When integrated with VCF Automation, these policies can be enforced consistently across tenants to maintain a uniform security and compliance posture. Policy definitions can be tailored to specific organizational requirements, providing an auditable record of the standards applied to each tenant. The Infrastructure Policies view in the DSM dashboard provides visibility into which policies are active and which databases are associated with them.

DSM provides a compliance report for each data service policy that displays policy violations, noncompliant databases, data services, and namespaces, giving administrators a structured view of deviations from defined organizational standards. DSM also generates infrastructure policy compliance alerts that allow administrators to monitor whether clusters are operating in conformance with defined infrastructure policies. Infrastructure policies create guardrails that restrict the quality and quantity of resources DSM users can consume from vSphere clusters, providing a mechanism for documented resource governance that can be presented to auditors as evidence of enforced controls.

For resilience conformity, DSM supports automated database backups with configurable schedules (full and incremental), configurable retention periods, and configurable storage locations using S3-compatible object stores, local storage, or cloud targets. DSM retains automated backups of deleted databases until the configured retention policy is met, and administrators can edit the retention period for retained backups. Backups can be enabled or modified after database creation via the automated-backups setting. Control plane backups are stored in S3 object storage with unique identifiers corresponding to the control plane ID. Backup operations are logged at the error level to both console and file outputs, providing an operational audit trail for backup activity. These capabilities allow an organization to demonstrate that database resilience controls are in place and configured within defined parameters.

Demonstrating conformity to applicable laws, regulations, or contractual obligations requires organizational processes beyond what DSM provides directly. Organizations must map DSM's configuration and operational evidence to the specific requirements of applicable frameworks, collect and maintain that evidence, and manage formal attestation processes. DSM provides technical controls and configuration visibility that form part of the evidentiary foundation, but formal compliance documentation, evidence management, and audit reporting remain organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides configuration export, backup management, and auditable policy artifacts that organizations can use when demonstrating security capability conformity for their application delivery infrastructure.

The Avi Controller CLI includes an export command to capture the full system configuration or an individual virtual service configuration. These exports document the security settings, WAF policies, and access control rules in effect at the time of capture and can be retained as part of a compliance documentation package. In VCF deployments, VCF Operations is used to configure the external backup server and storage path for Avi Load Balancer backups, and backups are stored on the same server as VCF Operations appliance backups by default. For deployments where the Controller runs as a single node,

enabling periodic external configuration backups is a mandatory requirement to handle recovery in the case of a complete VM or disk failure.

Configuration backup files can be protected with a passphrase, keeping audit artifacts secure in storage. When a restore is performed, the Controller requires that the passphrase match the one used when creating the backup, validates that all file objects from the backup configuration are present before the restore can proceed, and verifies that the FIPS mode of the backup configuration matches the controller environment. This set of integrity checks supports the reliability of configuration records used as audit documentation.

For application security evidence, Avi's WAF Positive Security model allows administrators to define and document allowed application behavior through explicit policy rules, forming part of the evidence set for application security controls. Avi also provides User-Defined Metrics, which allow administrators to define and extract customized telemetry data required for specific compliance or reporting needs via API calls.

On the administrative access side, Avi supports role-based access control with object-level permissions that can be applied to roles and inherited by user groups. The ability to export certificates and private keys is restricted to the fewest number of administrators possible. The Auth Mapping Profile feature supports LDAP group match rules and attribute-based role assignments, enabling a verifiable access control posture that can be reviewed during an audit.

Control 14.1

> A manufacturer shall notify any actively exploited vulnerability contained in the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that actively exploited vulnerability via the single reporting platform established pursuant to Article 16.

SCF Controls: TDA-02.13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.3

> A manufacturer shall notify any severe incident having an impact on the security of the product with digital elements that it becomes aware of simultaneously to the CSIRT designated as coordinator, in accordance with paragraph 7 of this Article, and to ENISA. The manufacturer shall notify that incident via the single reporting platform established pursuant to Article 16.

SCF Controls: IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 14.8

> After becoming aware of an actively exploited vulnerability or a severe incident having an impact on the security of the product with digital elements, the manufacturer shall inform the impacted users of the product with digital elements, and where appropriate all users, of that vulnerability or incident and, where necessary, of any risk mitigation and corrective measures that the users can deploy to mitigate the impact of that vulnerability or incident, where appropriate in a structured, machine-readable format that is easily automatically processable. Where the manufacturer fails to inform the users of the product with digital elements in a timely manner, the notified CSIRTs designated as coordinators may provide such information to the users when considered to be proportionate and necessary for preventing or mitigating the impact of that vulnerability or incident.

SCF Controls: IRO-10.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.1

> A manufacturer may, by a written mandate, appoint an authorised representative.

SCF Controls: CPL-08

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.3

> An authorised representative shall perform the tasks specified in the mandate received from the manufacturer. The authorised representative shall provide a copy of the mandate to the market surveillance authorities upon request. The mandate shall allow the authorised representative to do at least the following:

SCF Controls: CPL-08.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.3(a)

> keep the EU declaration of conformity referred to in Article 28 and the technical documentation referred to in Article 31 at the disposal of the market surveillance authorities for at least 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer;

SCF Controls: CPL-08.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.3(b)

> further to a reasoned request from a market surveillance authority, provide that authority with all the information and documentation necessary to demonstrate the conformity of the product with digital elements;

SCF Controls: CPL-08.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 18.3(c)

> cooperate with the market surveillance authorities, at their request, on any action taken to eliminate the risks posed by a product with digital elements covered by the authorised representative's mandate.

SCF Controls: CPL-08.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.1

> Importers shall place on the market only products with digital elements that comply with the essential cybersecurity requirements set out in Part I of Annex I and where the processes put in place by the manufacturer comply with the essential cybersecurity requirements set out in Part II of Annex I.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.2

> Before placing a product with digital elements on the market, importers shall ensure that:

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.2(a)

> the appropriate conformity assessment procedures as referred to in Article 32 have been carried out by the manufacturer;

SCF Controls: CPL-01.4, TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.2(b)

> the manufacturer has drawn up the technical documentation;

SCF Controls: TDA-01.1, TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.2(c)

> the product with digital elements bears the CE marking referred to in Article 30 and is accompanied by the EU declaration of conformity referred to in Article 13(20) and the information and instructions to the user as set out in Annex II in a language which can be easily understood by users and market surveillance authorities;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.3

> Where an importer considers or has reason to believe that a product with digital elements or the processes put in place by the manufacturer are not in conformity with this Regulation, the importer shall not place the product on the market until that product or the processes put in place by the manufacturer have been brought into conformity with this Regulation.

Furthermore, where the product with digital elements presents a significant cybersecurity risk, the importer shall inform the manufacturer and the market surveillance authorities to that effect.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.4

> Importers shall indicate their name, registered trade name or registered trademark, the postal address, email address or other digital contact as well as, where applicable, the website at which they can be contacted on the product with digital elements or on its packaging or in a document accompanying the product with digital elements. The contact details shall be in a language easily understood by users and market surveillance authorities.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.5

> Importers who know or have reason to believe that a product with digital elements which they have placed on the market is not in conformity with this Regulation shall immediately take the corrective measures necessary to ensure that the product with digital elements is brought into conformity with this Regulation, or to withdraw or recall the product, if appropriate.

SCF Controls: CPL-02.3, TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 19.6

> Importers shall, for at least 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer, keep a copy of the EU declaration of conformity at the disposal of the market surveillance authorities and ensure that the technical documentation can be made available to those authorities, upon request.

SCF Controls: DCH-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable data retention controls within VCF Operations that allow administrators to align operational data retention periods with organizational requirements. These controls do not address the full scope of media and data retention governance, but they give administrators granular tuning over how long different categories of platform-generated data are kept.

VCF Operations exposes data retention settings through Administration > Global Settings > Data Retention. Administrators can configure retention periods independently for several data categories. Metrics data supports a retention window between 1 month and 13 months. Entities and configuration data can be retained for a minimum of 1 month and a maximum of 3 months. Organization reports support a maximum data retention period of 1,440 days. At the normal retention tier, VCF Operations retains data at 5-minute granularity for 6 months, then rolls up the seventh month into 1-hour aggregations. A real-time retention tier provides 5-minute granularity, a standard tier retains data for 1 month, and a long-term tier retains data for 13 months. Different data retention policies can be configured and controlled for each category according to organizational requirements. Log data is governed separately through VCF Log Management, where administrators define log partitions that each carry their own retention period in days, with logs removed from disk automatically once a partition's period elapses and the option to archive partitions to external NFS or S3 storage for longer-term preservation.

VCF Operations for Networks provides additional granular retention controls. The default data retention period is 1 month in the advanced license edition. Flow data retention is fixed at a 1-month window within the platform. For organizations that need to retain flow data beyond one month, the Streaming Databus provides a mechanism to export flows to an external subscriber via HTTPS/HTTP for extended retention. Miscellaneous data retention can be configured with up to 100 GB of additional disk space.

VCF Operations also provides backup capabilities that support regulatory and operational retention needs. Administrators can take regular backups of both custom and out-of-the-box content. When reducing an entity metrics retention period in VCF Operations for Networks, the recommendation is to back up log files first to prevent data loss, which supports the principle of preserving data before modifying retention windows.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds Kubernetes-native persistent storage lifecycle controls relevant to data retention for containerized workloads. Persistent volumes in Supervisor namespaces store application data outside the lifecycle of individual pods and workloads, so data remains available when workloads restart or scale. The central mechanism governing retention behavior is the PersistentVolume reclaim policy, which controls what happens to the underlying storage and its data when the associated PersistentVolumeClaim is deleted. The Retain policy preserves the volume and its data in a Released state for manual administrator reclamation, leaving the data intact for inspection, archival, or transfer before final disposal. The Delete policy causes the storage asset to be removed when the claim is released. Retain is the default for manually provisioned PersistentVolumes. StorageClass definitions carry a ReclaimPolicy field that sets the default behavior for all dynamically provisioned volumes within a given storage class, allowing cluster administrators to enforce organization-wide retention defaults at the storage class level rather than per-volume. For StatefulSet workloads, Kubernetes provides a persistentVolumeClaimRetentionPolicy setting with a whenDeleted field that controls whether PVCs and their backing volumes are retained or deleted when the StatefulSet is removed; scaling a StatefulSet down does not delete the associated volumes by default. Organizations subject to retention obligations should configure StorageClasses with the Retain policy so that workload termination does not destroy data that must be kept for a defined period.

Storage Policy Based Management (SPBM) provides a unified control plane across VKS storage, enabling storage policies to be associated with persistent volumes that capture the storage characteristics required by a given workload or retention regime. VKS clusters surface a storage compliance status per volume: a Compliant status indicates that the datastore backing the volume satisfies the requirements of the associated policy; an Out of Date status indicates the policy has been updated but the new requirements have not yet been communicated to the datastore, requiring the policy to be reapplied to bring the volume back into compliance. This policy-driven model allows administrators to codify storage requirements and verify adherence continuously.

For Harbor Registry deployments on VKS clusters, administrators should note that configuring a StorageClass or PersistentVolume with a Delete reclaim policy results in all Harbor data being deleted when the Harbor package is removed. Image artifact retention requirements should drive reclaim policy selection for Harbor-backing storage. Platform teams should also manage data protection storage locations in VCF Automation to align with company-specific data residency and infrastructure standards.

These retention controls apply to the operational, monitoring, and configuration data that VCF Operations collects and manages, and to the persistent volume lifecycle for containerized workloads on VKS. They do not extend to application data stored within virtual machines outside the Kubernetes layer, user-generated content on datastores not managed by Kubernetes, or media outside the VCF platform. Organizations must establish broader data retention policies, classification schemes, and lifecycle management processes that address all media and data types subject to statutory, regulatory, and contractual obligations. VCF's retention settings are one component of a larger retention program that requires organizational governance, legal review of applicable obligations, and potentially additional tools for archival and disposition of data beyond what VCF Operations and VKS storage lifecycle controls manage.

VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 19.7

> Importers shall, further to a reasoned request from a market surveillance authority, provide it with all the information and documentation, in paper or electronic form, necessary to demonstrate the conformity of the product with digital elements with the essential cybersecurity requirements set out in Part I of Annex I as well as of the processes put in place by the manufacturer with the essential cybersecurity requirements set out in Part II of Annex I in a language that can be easily understood by that authority. They shall cooperate with that authority, at its request, on any measures taken to eliminate the cybersecurity risks posed by a product with digital elements, which they have placed on the market.

SCF Controls: CPL-03.3

Aggregate Coverage: Contributes

VCF (Contributes)

The control requires granting assessors minimum necessary access to conduct conformity assessments, including logical access to design, development, production, inspection, and testing artifacts, as well as physical access to facilities. VCF provides granular role-based access control mechanisms across its components that allow organizations to create appropriately scoped accounts for assessors conducting compliance or security assessments.

VMware vCenter implements a privilege system where privileges are grouped into roles that can be mapped to users or groups. The platform includes a built-in Read Only role that grants three system-defined privileges (System.Anonymous, System.View, and System.Read), providing a baseline for assessor access that allows viewing configuration and operational data without the ability to modify the environment. Read privileges can be assigned at the datacenter or vCenter level, allowing organizations to scope assessor visibility to specific portions of the infrastructure. For more tailored access, vCenter supports custom role creation with granular privilege assignment and permission propagation to vSphere objects, enabling organizations to build assessor-specific roles that include only the privileges needed for a particular assessment engagement. The operator role in vCenter provides another restricted authorization level where users can view information about vCenter but cannot alter its configuration. VCF SSO also includes a SystemConfiguration.ReadOnly privilege that grants members read-only access to vCenter appliance operations under Appliance Management, providing a targeted option for assessors whose scope includes appliance configuration review. New users and groups are assigned the No Access role by default in vCenter, so assessor accounts start with no visibility and require explicit permission assignments before any infrastructure objects become accessible.

VCF Operations provides its own ReadOnly role that allows users to perform read operations but restricts write actions such as create, update, or delete. Permissions for specific functional areas, such as Infrastructure Operations and the Analyze page, are managed in the Roles tab under Administration > Control Panel, where individual permissions can be selected or deselected when adding or editing a role. This granularity allows organizations to tailor assessor access to the specific operational data relevant to the assessment scope.

VCF Automation includes several roles suited to assessor access. The Organization Auditor role provides read-only access equivalent to the Organization Administrator role, allowing auditors to view anything an administrator can see without the ability to edit or manage users and groups. The Project Auditor role is similarly restricted to read-only access at the project level. The Project Viewer role is restricted to read-only access, except in cases where viewers can perform non-destructive actions such as downloading cloud templates. Organizations can also create custom user roles in VCF Automation to expand or restrict permissions for specific project resources without granting broader administrative capability.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, provides a dedicated access control framework for granting assessors minimum-necessary access to Kubernetes workloads and related artifacts. At the vSphere Namespace level, administrators can assign VCF SSO users and groups to one of three permission levels: Can View, Can Edit, or Owner. The Can View role grants read-only access to VKS cluster objects provisioned in the namespace and maps no permissions to Kubernetes roles within those clusters, making it appropriate for assessors who need to review namespace-scoped workload configurations without the ability to modify cluster resources. VCF Consumption CLI access to vSphere Namespaces is enforced based on user permissions, and users without sufficient permissions cannot connect to the Supervisor or its VKS clusters. Within VKS clusters, Kubernetes RBAC provides the built-in

view ClusterRole, which gives read-only access to most objects in a namespace but excludes visibility into roles and role bindings, allowing assessors to inspect workload and policy configurations without being able to examine or modify the cluster's access control structure. Administrators can also create custom Roles and RoleBindings scoped to specific namespaces, and Kubernetes ABAC rules support a readonly access mode to restrict users to read-only operations on specified resources. Kubernetes RBAC enforces that a RoleBinding cannot grant permissions the grantor does not already hold, which prevents privilege escalation when provisioning assessor accounts. RoleBinding subjects in VKS clusters must reference VCF SSO user or group names, keeping assessor identity management integrated with the platform's central identity directory. Access to the VKS Policy Insights page, which provides centralized visibility into the governance health of the VKS cluster estate, is restricted to the Organization Auditor and related roles, allowing organizations to grant assessors read-only policy visibility without broader operational rights. Harbor Registry, available as a standard package on VKS clusters, enforces RBAC to control access to container image artifacts, allowing organizations to grant assessors read access to specific image repositories relevant to their assessment scope.

The platform's authorization model verifies what objects each principal has access to, and the recommendation across VCF components is to configure users with the specific privileges required for their role rather than assigning overly permissive roles. Organizations should define assessor-specific roles in each VCF component that grant read access only to the artifacts relevant to the assessment scope.

VCF supports identity federation through standard protocols, which allows assessor accounts to be provisioned through an organization's existing identity provider rather than creating local accounts. Identity provider federation uses token-based authentication and supports multifactor authentication. This simplifies lifecycle management and helps ensure assessor credentials are deprovisioned when the engagement ends.

VCF also provides audit logging capabilities that create a record of assessor actions during an engagement. VCF Operations user activity audit reports provide traceability of user activities including logging in, actions on clusters and nodes, changes to system passwords, activating certificates, and logging out. These audit logs can be downloaded in PDF or XLS format. VCF Automation audit logs capture action details including timestamps, user names, project names, and trace IDs. This auditability allows organizations to verify that assessors operated within the bounds of their granted access.

Physical access to facilities is outside VCF's scope as a software platform. Organizations must address physical facility access through their own site security and visitor management processes.

VMware vDefend (Contributes)

VMware vDefend contributes to granting assessors minimum necessary logical access through the role-based access control (RBAC) framework of its Security Services Platform. The framework defines three permission levels: Full Access, which encompasses create, read, update, and delete operations; Read, which provides read-only visibility; and No Access, which excludes all operations.

A dedicated Auditor role is available for personnel who need to review configurations without making changes. In VMware vDefend, the Auditor role holds Read permissions for platform operations including deploying, managing, and upgrading the Security Services Platform, configuring authentication and authorization, performing server configuration, managing backup and restore, and activating Security Intelligence. The Auditor role also has Full Access to view Rule Analysis results and download rule analysis reports, giving assessors the ability to examine how firewall policy rules align with observed traffic behavior. For other operations, including exporting data, publishing segmentation policies and group definitions, managing discovery and inventory assets, and configuring Security Intelligence data collection, the Auditor role holds Restricted permissions that limit its ability to alter state.

Five platform roles are defined with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Enterprise Admin and Security Engineer hold Full Access to export traffic flows, monitor infrastructure, environment, and application telemetry, configure Security Intelligence data collection, and visualize traffic flows. This role hierarchy allows administrators to assign the Auditor role to assessors while granting elevated operational permissions only to engineering and administrative staff.

Physical access to facilities is outside the scope of VMware vDefend and must be addressed through separate facility access management processes and organizational controls.

VMware VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access control (RBAC) mechanisms that support granting assessors minimum necessary logical access to disaster recovery artifacts.

PNR restricts login to VMware vCenter administrators by default; other users require an explicit permission grant from an administrator to access PNR. Permissions are required on both vCenter objects and PNR-specific objects, giving administrators granular control over what each user can see and do within the platform. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, making the permission model consistent across sites in a two-site configuration.

For assessors who need access to recovery plan operations without full administrative rights, permissions for testing and running recovery plans can be assigned separately in PNR. In shared recovery site configurations, the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use protection and recovery for their own protected site without access to resources belonging to other organizations. Site-wide permission assignments must be added on a per-site basis, with corresponding permissions required on both the protected and recovery sites. Users or user groups assigned a PNR role that are not vCenter administrators do not obtain vSphere Replication privileges; assessors who require access to both PNR operations and vSphere Replication should be placed in separate user groups for each role type, avoiding the need to grant full vCenter administrator privileges.

When PNR is deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, providing additional scoping options for multi-tenant environments.

PNR also includes a Clean Room Orchestrator where access is restricted to IP addresses and IP address ranges configured in a management access list, limiting which hosts can reach the clean room environment used for ransomware recovery and analysis.

Physical access to facilities is outside the scope of PNR and remains an organizational responsibility.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides role-based access control in the Avi Controller that administrators can use to create role-scoped accounts for assessors, granting minimum necessary access to the application delivery environment. Avi roles define two distinct access types: Write privilege allows users to create, read, modify, and delete resources, while Read privilege restricts users to reading existing configuration, viewing health and analytics data, and viewing audit logs without modification capability. This allows assessor accounts to be provisioned with observation-only access across the application delivery tier.

Avi includes a dedicated Auditor role that grants Read access to view security services platform configuration, upgrades, and authentication and authorization configuration in the Avi Controller without the ability to make changes. Assessors can be assigned this role to gain visibility into the security posture of the application delivery environment without receiving any write capability.

Within the Controller administration interface, accounts can be assigned to specific roles and tenants, allowing narrowly scoped access to virtual service configurations, WAF policies, application analytics, SSL/TLS certificate profiles, health monitor definitions, analytics profiles, and application event and audit logs. Avi's extended granular role-based access control also supports sub-resource-level permissions, enabling role definitions that restrict access to specific pool sub-resources. The ability to export certificates and private keys is separately controlled through RBAC, and Avi documentation recommends restricting this capability to the fewest number of administrators possible.

Avi supports local accounts and integration with external identity providers including LDAP, SAML, TACACS+, and OAuth/OIDC, allowing organizations to provision assessor accounts through existing identity governance processes rather

than creating standalone credentials. Role assignments can be scoped to specific tenants, which is useful when an assessment covers only a subset of the application delivery environment. In Kubernetes deployments using the Avi Kubernetes Operator (AKO), the ako-all-tenants-permission-controller role provides cross-tenant read access for assessors who need visibility across multiple namespaces.

This control asks whether the organization grants assessors minimum necessary access to design, development, production, inspection, and testing artifacts, and whether physical access to facilities is managed. Avi's RBAC addresses the application delivery tier. Meeting this control in full requires the organization to define the scope of each assessment, coordinate access provisioning across all relevant VCF platform components, and manage physical access to facilities. None of those dimensions fall within Avi's scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 20.1

> When making a product with digital elements available on the market, distributors shall act with due care in relation to the requirements set out in this Regulation.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 20.2

> Before making a product with digital elements available on the market, distributors shall verify that:

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 20.2(a)

> the product with digital elements bears the CE marking;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 20.2(b)

> the manufacturer and the importer have complied with the obligations set out in Article 13(15), (16), (18), (19) and (20) and Article 19(4), and have provided all necessary documents to the distributor.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 20.3

> Where a distributor considers or has reason to believe, on the basis of information in its possession, that a product with digital elements or the processes put in place by the manufacturer are not in conformity with the essential cybersecurity requirements set out in Annex I, the distributor shall not make the product with digital elements available on the market until that product or the processes put in place by the manufacturer have been brought into conformity with this Regulation. Furthermore, where the product with digital elements poses a significant cybersecurity risk, the distributor shall inform, without undue delay, the manufacturer and the market surveillance authorities to that effect.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 20.4

> Distributors who know or have reason to believe, on the basis of information in their possession, that a product with digital elements, which they have made available on the market, or the processes put in place by its manufacturer are not in conformity with this Regulation shall make sure that the corrective measures necessary to bring that product with digital elements or the processes put in place by its manufacturer into conformity, or to withdraw or recall the product, if appropriate, are taken.

SCF Controls: CPL-02.3, TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 20.5

> Distributors shall, further to a reasoned request from a market surveillance authority, provide all the information and documentation, in paper or electronic form, necessary to demonstrate the conformity of the product with digital elements and the processes put in place by its manufacturer with this Regulation in a language that can be easily understood by that authority. They shall cooperate with that authority, at its request, on any measures taken to eliminate the cybersecurity risks posed by a product with digital elements which they have made available on the market.

SCF Controls: CPL-03.3

Aggregate Coverage: Contributes

VCF (Contributes)

The control requires granting assessors minimum necessary access to conduct conformity assessments, including logical access to design, development, production, inspection, and testing artifacts, as well as physical access to facilities. VCF provides granular role-based access control mechanisms across its components that allow organizations to create appropriately scoped accounts for assessors conducting compliance or security assessments.

VMware vCenter implements a privilege system where privileges are grouped into roles that can be mapped to users or groups. The platform includes a built-in Read Only role that grants three system-defined privileges (System.Anonymous, System.View, and System.Read), providing a baseline for assessor access that allows viewing configuration and operational data without the ability to modify the environment. Read privileges can be assigned at the datacenter or vCenter level, allowing organizations to scope assessor visibility to specific portions of the infrastructure. For more tailored access, vCenter supports custom role creation with granular privilege assignment and permission propagation to vSphere objects, enabling organizations to build assessor-specific roles that include only the privileges needed for a particular assessment engagement. The operator role in vCenter provides another restricted authorization level where users can view information about vCenter but cannot alter its configuration. VCF SSO also includes a SystemConfiguration.ReadOnly privilege that grants members read-only access to vCenter appliance operations under Appliance Management, providing a targeted option for assessors whose scope includes appliance configuration review. New users and groups are assigned the No Access role by default in vCenter, so assessor accounts start with no visibility and require explicit permission assignments before any infrastructure objects become accessible.

VCF Operations provides its own ReadOnly role that allows users to perform read operations but restricts write actions such as create, update, or delete. Permissions for specific functional areas, such as Infrastructure Operations and the Analyze page, are managed in the Roles tab under Administration > Control Panel, where individual permissions can be selected or deselected when adding or editing a role. This granularity allows organizations to tailor assessor access to the specific operational data relevant to the assessment scope.

VCF Automation includes several roles suited to assessor access. The Organization Auditor role provides read-only access equivalent to the Organization Administrator role, allowing auditors to view anything an administrator can see without the ability to edit or manage users and groups. The Project Auditor role is similarly restricted to read-only access at the project level. The Project Viewer role is restricted to read-only access, except in cases where viewers can perform non-destructive actions such as downloading cloud templates. Organizations can also create custom user roles in VCF Automation to expand or restrict permissions for specific project resources without granting broader administrative capability.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, provides a dedicated access control framework for granting assessors minimum-necessary access to Kubernetes workloads and related artifacts. At the vSphere Namespace level, administrators can assign VCF SSO users and groups to one of three permission levels: Can View, Can Edit, or Owner. The Can View role grants read-only access to VKS cluster objects provisioned in the namespace and maps no permissions to Kubernetes roles within those clusters, making it appropriate for assessors who need to review namespace-scoped workload configurations without the ability to modify cluster resources. VCF Consumption CLI access to vSphere Namespaces is enforced based on user permissions, and users without sufficient permissions cannot connect to the Supervisor or its VKS clusters. Within VKS clusters, Kubernetes RBAC provides the built-in view ClusterRole, which gives read-only access to most objects in a namespace but excludes visibility into roles and role

bindings, allowing assessors to inspect workload and policy configurations without being able to examine or modify the cluster's access control structure. Administrators can also create custom Roles and RoleBindings scoped to specific namespaces, and Kubernetes ABAC rules support a readonly access mode to restrict users to read-only operations on specified resources. Kubernetes RBAC enforces that a RoleBinding cannot grant permissions the grantor does not already hold, which prevents privilege escalation when provisioning assessor accounts. RoleBinding subjects in VKS clusters must reference VCF SSO user or group names, keeping assessor identity management integrated with the platform's central identity directory. Access to the VKS Policy Insights page, which provides centralized visibility into the governance health of the VKS cluster estate, is restricted to the Organization Auditor and related roles, allowing organizations to grant assessors read-only policy visibility without broader operational rights. Harbor Registry, available as a standard package on VKS clusters, enforces RBAC to control access to container image artifacts, allowing organizations to grant assessors read access to specific image repositories relevant to their assessment scope.

The platform's authorization model verifies what objects each principal has access to, and the recommendation across VCF components is to configure users with the specific privileges required for their role rather than assigning overly permissive roles. Organizations should define assessor-specific roles in each VCF component that grant read access only to the artifacts relevant to the assessment scope.

VCF supports identity federation through standard protocols, which allows assessor accounts to be provisioned through an organization's existing identity provider rather than creating local accounts. Identity provider federation uses token-based authentication and supports multifactor authentication. This simplifies lifecycle management and helps ensure assessor credentials are deprovisioned when the engagement ends.

VCF also provides audit logging capabilities that create a record of assessor actions during an engagement. VCF Operations user activity audit reports provide traceability of user activities including logging in, actions on clusters and nodes, changes to system passwords, activating certificates, and logging out. These audit logs can be downloaded in PDF or XLS format. VCF Automation audit logs capture action details including timestamps, user names, project names, and trace IDs. This auditability allows organizations to verify that assessors operated within the bounds of their granted access.

Physical access to facilities is outside VCF's scope as a software platform. Organizations must address physical facility access through their own site security and visitor management processes.

VMware vDefend (Contributes)

VMware vDefend contributes to granting assessors minimum necessary logical access through the role-based access control (RBAC) framework of its Security Services Platform. The framework defines three permission levels: Full Access, which encompasses create, read, update, and delete operations; Read, which provides read-only visibility; and No Access, which excludes all operations.

A dedicated Auditor role is available for personnel who need to review configurations without making changes. In VMware vDefend, the Auditor role holds Read permissions for platform operations including deploying, managing, and upgrading the Security Services Platform, configuring authentication and authorization, performing server configuration, managing backup and restore, and activating Security Intelligence. The Auditor role also has Full Access to view Rule Analysis results and download rule analysis reports, giving assessors the ability to examine how firewall policy rules align with observed traffic behavior. For other operations, including exporting data, publishing segmentation policies and group definitions, managing discovery and inventory assets, and configuring Security Intelligence data collection, the Auditor role holds Restricted permissions that limit its ability to alter state.

Five platform roles are defined with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Enterprise Admin and Security Engineer hold Full Access to export traffic flows, monitor infrastructure, environment, and application telemetry, configure Security Intelligence data collection, and visualize traffic flows. This role hierarchy allows administrators to assign the Auditor role to assessors while granting elevated operational permissions only to engineering and administrative staff.

Physical access to facilities is outside the scope of VMware vDefend and must be addressed through separate facility access management processes and organizational controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access control (RBAC) mechanisms that support granting assessors minimum necessary logical access to disaster recovery artifacts.

PNR restricts login to VMware vCenter administrators by default; other users require an explicit permission grant from an administrator to access PNR. Permissions are required on both vCenter objects and PNR-specific objects, giving administrators granular control over what each user can see and do within the platform. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, making the permission model consistent across sites in a two-site configuration.

For assessors who need access to recovery plan operations without full administrative rights, permissions for testing and running recovery plans can be assigned separately in PNR. In shared recovery site configurations, the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use protection and recovery for their own protected site without access to resources belonging to other organizations. Site-wide permission assignments must be added on a per-site basis, with corresponding permissions required on both the protected and recovery sites. Users or user groups assigned a PNR role that are not vCenter administrators do not obtain vSphere Replication privileges; assessors who require access to both PNR operations and vSphere Replication should be placed in separate user groups for each role type, avoiding the need to grant full vCenter administrator privileges.

When PNR is deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, providing additional scoping options for multi-tenant environments.

PNR also includes a Clean Room Orchestrator where access is restricted to IP addresses and IP address ranges configured in a management access list, limiting which hosts can reach the clean room environment used for ransomware recovery and analysis.

Physical access to facilities is outside the scope of PNR and remains an organizational responsibility.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides role-based access control in the Avi Controller that administrators can use to create role-scoped accounts for assessors, granting minimum necessary access to the application delivery environment. Avi roles define two distinct access types: Write privilege allows users to create, read, modify, and delete resources, while Read privilege restricts users to reading existing configuration, viewing health and analytics data, and viewing audit logs without modification capability. This allows assessor accounts to be provisioned with observation-only access across the application delivery tier.

Avi includes a dedicated Auditor role that grants Read access to view security services platform configuration, upgrades, and authentication and authorization configuration in the Avi Controller without the ability to make changes. Assessors can be assigned this role to gain visibility into the security posture of the application delivery environment without receiving any write capability.

Within the Controller administration interface, accounts can be assigned to specific roles and tenants, allowing narrowly scoped access to virtual service configurations, WAF policies, application analytics, SSL/TLS certificate profiles, health monitor definitions, analytics profiles, and application event and audit logs. Avi's extended granular role-based access control also supports sub-resource-level permissions, enabling role definitions that restrict access to specific pool sub-resources. The ability to export certificates and private keys is separately controlled through RBAC, and Avi documentation recommends restricting this capability to the fewest number of administrators possible.

Avi supports local accounts and integration with external identity providers including LDAP, SAML, TACACS+, and OAuth/OIDC, allowing organizations to provision assessor accounts through existing identity governance processes rather than creating standalone credentials. Role assignments can be scoped to specific tenants, which is useful when an assessment covers only a subset of the application delivery environment. In Kubernetes deployments using the Avi Kubernetes Operator

(AKO), the ako-all-tenants-permission-controller role provides cross-tenant read access for assessors who need visibility across multiple namespaces.

This control asks whether the organization grants assessors minimum necessary access to design, development, production, inspection, and testing artifacts, and whether physical access to facilities is managed. Avi's RBAC addresses the application delivery tier. Meeting this control in full requires the organization to define the scope of each assessment, coordinate access provisioning across all relevant VCF platform components, and manage physical access to facilities. None of those dimensions fall within Avi's scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 31.1

> The technical documentation shall contain all relevant data or details of the means used by the manufacturer to ensure that the product with digital elements and the processes put in place by the manufacturer comply with the essential cybersecurity requirements set out in Annex I. It shall at least contain the elements set out in Annex VII.

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 31.2

> The technical documentation shall be drawn up before the product with digital elements is placed on the market and shall be continuously updated, where appropriate, at least during the support period.

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 31.3

> For products with digital elements as referred to in Article 12, which are also subject to other Union legal acts which provide for technical documentation, a single set of technical documentation shall be drawn up containing the information referred to in Annex VII and the information required by those Union legal acts.

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 31.4

> The technical documentation and correspondence relating to any conformity assessment procedure shall be drawn up in an official language of the Member State in which the notified body is established or in a language acceptable to that body.

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 32.1

> The manufacturer shall perform a conformity assessment of the product with digital elements and the processes put in place by the manufacturer to determine whether the essential cybersecurity requirements set out in Annex I are met. The manufacturer shall demonstrate conformity with the essential cybersecurity requirements by using any of the following procedures:

SCF Controls: CPL-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The BadgeCompliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual

obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 32.1(a)

> the internal control procedure (based on module A) set out in Annex VIII;

SCF Controls: CPL-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The Badge|Compliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 32.2(a)

> the EU-type examination procedure (based on module B) set out in Annex VIII followed by conformity to EU-type based on internal production control (based on module C) set out in Annex VIII; or

SCF Controls: CPL-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The BadgeCompliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 32.2(b)

> a conformity assessment based on full quality assurance (based on module H) set out in Annex VIII.

SCF Controls: CPL-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The Badge|Compliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (1)

> Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.

SCF Controls: TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(a)

> be made available on the market without known exploitable vulnerabilities;

SCF Controls: TDA-02.8

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that help organizations reduce the attack surface of their virtualized infrastructure, though a complete attack surface minimization program requires organizational processes and tooling beyond what the platform itself delivers.

VCF Operations tracks security advisories and available updates for all VCF components, alerting administrators when patches or fixes are available. VCF's patch management architecture supports selective, component-level patching. Patch releases deliver time-sensitive fixes to security issues and can be applied to individual components without requiring synchronized updates across all VCF components. This design allows organizations to respond quickly to newly disclosed vulnerabilities without the overhead of a full-stack upgrade cycle. Lifecycle management automates the process of applying updates across ESX hosts, vCenter, NSX, and other stack components, reducing the window during which known vulnerabilities remain unpatched. VMware publishes security advisories (VMSAs) for critical known vulnerabilities across VCF components, including VCF Operations and VCF Operations for Networks, with step-by-step remediation instructions. Keeping components at their latest versions is recommended to take advantage of all available security fixes.

VCF includes a security compliance engine that can discover objects across the environment that are not compliant with a defined security standard. The platform supports compliance checking against the Security Configuration Guide and the DISA STIG, giving operators a systematic way to assess and remediate hardening gaps across VCF components. Built-in compliance checks report objects that are not compliant with these hardening standards, allowing administrators to identify and address configuration weaknesses. vCenter also supports user-defined security baselines, allowing security administrators to define custom security standards and compare both ESX hosts and virtual machines against those baselines to identify and remediate deviations.

Configuration Profiles and Image-Based Lifecycle Management allow administrators to define a desired host configuration baseline and detect drift from that baseline. When hosts deviate from the approved configuration, drift detection flags the change so administrators can remediate it. This helps prevent configuration sprawl that can introduce new attack surface.

ESX host hardening is a core element of attack surface reduction within VCF. Recommended hardening steps include configuring authentication and authorization settings, disabling unnecessary services, enabling Secure Boot and Trusted Platform Module (TPM) support, and implementing network security measures. These measures collectively reduce the number of exposed services and entry points on each host.

The Consumption layer, delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor, provides additional attack surface minimization mechanisms for containerized workloads. Pod Security Admission (PSA) enforces security constraints across namespaces using Baseline, Restricted, and Privileged profiles; the Baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads, while the Restricted profile drops all Linux capabilities by default, directly reducing the OS-level attack surface available to container processes. Security contexts within pod specifications allow operators to restrict OS-level privileges on individual workloads. AppArmor and SELinux profiles applied through security context annotations restrict what container processes can access beyond the capability set, helping mitigate container runtime vulnerabilities. Seccomp profiles can reduce the Linux kernel syscall attack surface available inside containers by creating allow or deny lists of specific syscalls using BPF-named profiles. User namespaces map container root user IDs to unprivileged host UIDs, limiting potential damage from container breakout scenarios. Security Technical Implementation Guides (STIGs) for VKS system components, including Supervisor and VKS Releases (VKRs), are available to guide administrators through security-relevant configuration choices for the Consumption platform layer, and the vSphere Supervisor platform builds on vSphere security features in VMware vCenter and VMware ESX to provision workload clusters that are designed to be secure by default. Harbor Registry, available as a Supervisor service

package, provides vulnerability scanning, content trust, and policy-based access control for container artifacts, supporting limits on the introduction of known-vulnerable components into running workloads. The Consumption layer also supports integration with Harness Security Testing Orchestration, which scans container images across each layer and deduplicates vulnerability findings, presenting each unique issue as a single actionable item for development teams to address before workloads are promoted to production. Virtual machine images deployed through vSphere Supervisor should be built with the latest patches and required security settings following corporate security policies for production environments.

Network architecture within VCF contributes to attack surface reduction. In secure environments, the Workload Separation Distributed Switch Model provides physical air-gapped separation of network traffic, limiting lateral movement paths. NSX segment security filters traffic to protect segment integrity, and NSX Context Profiles and vDefend L7 Access Profiles provide application-layer traffic filtering. Security groups and security policies can be defined within NSX to enforce network-level isolation and access controls across the virtual environment. At the Kubernetes workload layer, network policies enforced through Antrea CNI restrict ingress and egress traffic at the namespace level, limiting lateral movement between workloads and reducing the scope of what a single compromised workload can reach. Service meshes, where deployed, extend this with Layer 7 workload-identity-based policies and mutual TLS for inter-service communication, further scoping traffic to declared service relationships.

VMware's internal security team maintains controls to minimize the security footprint of VCF components such as VCF Operations for Networks, reflecting a secure-by-design approach to the platform's own development and release process. VCF Operations for Networks is hardened against industry-accepted security benchmarks.

These capabilities provide the technical foundation for attack surface minimization, but the control also requires organizational vulnerability management processes, risk-based prioritization of remediation efforts, and regular assessment cycles that fall outside VCF's scope as an infrastructure platform. Minimizing the attack surface across all customer-deployed workloads and applications running on VCF requires additional organizational processes and tools beyond what VCF provides natively. For Kubernetes workloads on VKS, STIG hardening must be applied during cluster provisioning and validated periodically, security contexts must be configured in workload specifications, PSA enforcement modes must be set appropriately per namespace, and image scanning through Harbor must be integrated into deployment workflows consistently rather than treated as a one-time step.

VMware Private AI Services (PAIS) provides several AI-specific mechanisms that help reduce the attack surface of AI workloads, model artifacts, and AI catalog items.

The Model Gallery workflow includes organizational validation of ML models before they are made available to AI application developers. MLOps engineers validate models against the organization's security, privacy, and technical requirements before upload, evaluate model performance and safety by examining inference requests for malicious behavior, and perform hands-on functional tests before deployment. PAIS guidance recommends distributing models within the organization that have been validated on a deep learning VM rather than models pulled from the Internet, which could contain malicious code or be tuned for malicious behavior. The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models, limiting which identities can read or modify model content.

PAIS uses a CA trust bundle for secure communication with external services and databases, scoping outbound connectivity to authenticated, encrypted channels. Remote Model Context Protocol (MCP) servers connected to PAIS can optionally use static authentication tokens, restricting which clients can invoke remote tool capabilities. Custom forms in PAIS blueprints can be modified to control user inputs at request time, allowing tenants to constrain the parameters passed to AI catalog items before they are provisioned.

Broader vulnerability management activities, including patch management, vulnerability assessment of underlying infrastructure, and risk prioritization, remain outside PAIS's direct scope and depend on organizational processes together with the platform layers that host PAIS.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to minimizing attack surfaces through network-layer virtual patching, microsegmentation, and threat analysis capabilities.

The vDefend distributed firewall (DFW) enforces microsegmentation policies on virtualized workloads, isolating critical services to reduce their network-accessible attack surface and restricting lateral threat movement. The Security Services Platform identifies vulnerable workloads that could be exploited for lateral movement and provides network and transport layer protocol validation against low-level IP attacks.

The vDefend IDS/IPS engine uses knowledge-based signature rules that match patterns corresponding to known attack types, detecting and blocking network traffic associated with known exploitable vulnerabilities. Administrators can search and filter signatures by specific CVE identifiers and by attack target (client or server) to tune detection to the asset types in their environment. Security profiles allow selection of specific system signatures and custom signatures; custom signatures can be added for custom applications and zero-day vulnerabilities beyond the built-in library. The IDS/IPS also detects obsolete protocols through port verification and application identification, enabling operators to identify deprecated communication methods in active use. When a signature triggers, vDefend IDS/IPS and Malware Prevention automatically export PCAP files for forensic analysis of captured network traffic. The Gateway Firewall with Advanced Threat Prevention supports Cloud Sandboxing and Artifact Analysis for north-south traffic flows. Advanced Threat Prevention features including IDS, Network Traffic Analysis, and Network Detection and Response are operable in air-gapped environments.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows. These reports provide recommendations for applying DFW capabilities, presented as Projects that guide organizations through a staged Zero Trust journey from initial assessment to application-level microsegmentation.

Vulnerability remediation at the host and application layer, such as patching operating systems or application code, remains outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to attack surface minimization through network isolation controls, resource access restrictions, secure communications, and a structured patching mechanism. Full coverage of this control requires organizational processes and platform-level capabilities beyond DSM's own scope.

DSM's architecture requires VDS and N-VDS port groups to segregate database traffic from other network segments. Infrastructure policies, configured by vSphere administrators, establish limits and guardrails on the compute, memory, storage, and IP resources that DSM users can consume from vSphere clusters. These policies scope each user's access to a defined set of infrastructure components, reducing the potential blast radius of a compromised account or misconfiguration. IP pools define the address ranges assigned to database instances, and DSM detects network overlap between infrastructure policy IP ranges and system configuration networks, generating alerts and requiring that overlap to be resolved before provisioning proceeds. This validation step helps catch misconfigurations that could otherwise allow unintended network access between database tenants or between DSM-managed workloads and management networks.

When deployed in network-isolated environments, the DSM appliance bundles all necessary consumption operator artifacts locally, supporting air-gapped configurations where internet access is not available. Data service policies can be enforced consistently across different tenants, maintaining a uniform security posture regardless of who provisions a database.

DSM supports LDAPS for directory service connections, channeling administrator and user authentication over an encrypted connection. Connections to the DSM Provider VM are secured using TLS, with the Provider VM's certificate authority added to the trusted CA list. DSM verifies the SHA256 thumbprint of VMware vCenter during configuration, reducing the risk of connecting to an unauthorized or compromised vCenter instance. Database cluster connections use TLS for all supported database engines, including SQL Server, and the DSM UI provides a direct method to retrieve the CA certificate needed to establish those secure connections. These controls reduce the attack surface exposed by unencrypted management and application traffic.

The DSM Consumption Operator deployment includes Signature Verification validation to confirm package integrity before installation, reducing supply chain risk for managed workloads. DSM supports structured software update bundles for appliances and the DSM plug-in. The update mechanism requires at least one attempt to complete a chain of software updates, irrespective of the configured update window, supporting consistent application of security patches. Administrators

should apply available update bundles promptly to address known vulnerabilities in DSM components. The DSM UI also surfaces a compliance tab on data service policies, giving administrators visibility into policy adherence across managed databases.

DSM does not provide its own vulnerability scanning, intrusion detection, or firewall controls. Attack surface minimization at the platform level, including VMware ESX hardening, network segmentation, and vCenter access controls, is provided by the underlying VCF infrastructure. Organizations must maintain a vulnerability management program that identifies, prioritizes, and tracks remediation of known vulnerabilities across DSM and its supporting platform. Patch scheduling, testing procedures, and emergency response processes remain organizational responsibilities that DSM supports but does not replace.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that address attack surface minimization for applications it fronts.

WAF Application Rules are the primary mechanism for mitigating known exploitable vulnerabilities. These rules are specifically designed to block attacks on known application vulnerabilities, including those tracked as Common Vulnerabilities and Exposures (CVEs). Application Rules are automatically updated through Avi Load Balancer Cloud Services, so newly disclosed vulnerabilities can be addressed at the WAF layer without redeploying or modifying the underlying application. WAF signatures include detection for OWASP Top 10 attack vectors to maintain broad coverage across the attack surface.

In 9.1, the Live Security Threat Intelligence service, available through the Avi Cloud Console, delivers real-time security threat feeds covering various attack vectors for enabled Avi Load Balancer deployments. This feed complements the Application Rules with continuously updated threat intelligence, providing protection against evolving threats without manual rule updates.

Avi WAF supports a Positive Security model that reduces the attack surface from a complementary direction: rather than detecting known attack patterns, the Positive Security model restricts traffic to known-good application behavior through an allowlist built from sampled observed traffic. WAF policies should be configured to enable Positive Security protection using this traffic profile, which is maintained through the WAF allowlist sampling process.

For application teams using dynamic application security testing (DAST), Avi supports virtual patching through the Avi Load Balancer SDK, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning. DAST scanner results can be imported to identify and protect against potential security issues in applications before a code-level fix is available, reducing the window of exposure between discovery and remediation.

The Avi Kubernetes Operator (AKO) provides WAF integration for application-layer security in VMware Kubernetes Service (VKS) environments, extending attack surface minimization capabilities to Kubernetes-hosted workloads in Avi-for-VCF deployments.

Network-layer controls supplement the WAF layer. Network Security Policies block traffic from known-bad IP addresses by dropping TCP SYN packets before connections are established. The Avi Service Engine detects and mitigates a range of Layer 4 through Layer 7 network attacks, including IP fragmentation attacks, TCP SYN floods, HTTP SlowLoris attacks, and request floods. The Service Engine's data-plane architecture isolates attacks to the data plane, reducing the risk of impact to management interfaces. Configurable DDoS attack limits per application profile allow thresholds to be tuned to each application's expected traffic patterns. The Avi security penalty component monitors and reports active DoS attacks and SSL configuration vulnerabilities, providing visibility into the current threat posture.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control Annex I Part I (2)(b)

> be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state;

SCF Controls: TDA-02.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF ships with a documented security baseline that defines secure configurations for all platform components. This baseline allows organizations to evaluate both default and non-default settings and assists in securing information systems within a compliance context. The baseline is designed and validated so that tailoring security configurations does not impair VCF's ability to meet its design objectives, giving organizations confidence that applying the vendor-recommended secure settings will not break platform functionality. The baseline is published through the VMware Security Configuration Guide and through DISA STIGs and STIG Readiness Guides, which provide prescriptive hardening guidance for ESX hosts, vCenter, NSX, and other VCF components.

VCF provides component-level hardening guidance for each layer of the stack. The ESX Host Hardening guidance covers configuring authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. As part of the Secure ESX Configuration feature, ESX encrypts the archived configuration file with an encryption key stored in the TPM during the first boot after installation or upgrade. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access. These guides define the vendor-recommended secure posture that organizations can apply at initial deployment and reapply after upgrades.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) and vSphere Supervisor, also ships with vendor-published pre-established secure configuration baselines. DISA STIGs for Supervisor and VKr (Kubernetes release) nodes are available through Tanzu STIG Hardening, covering Supervisor control plane settings, node-level hardening, and workload isolation controls. VKS cluster security configurations are immutable and persistent by design, moving away from manual node-level configurations and preventing configuration drift across deployments and upgrades. At the workload level, Supervisor's Pod Security Admission controller enforces one of three Pod Security Standard profiles per namespace: Privileged, Baseline, or Restricted. The Restricted profile prohibits host namespace access, blocks privilege escalation, and restricts Seccomp profiles from being set to Unconfined; the Baseline profile reduces the most significant known privilege escalations while allowing a broader set of workloads. Namespace-level Pod Security Standard enforcement persists through cluster upgrades, carrying the pre-established security posture forward as the control requires. Pod Security Admission is enabled by default on VKS clusters and supports enforce, audit, and warn modes configured through namespace labels, allowing organizations to observe policy violations before moving to strict enforcement. The admission controller can also be statically configured to apply a default enforcement level to namespaces that have not been explicitly labeled, so new namespaces inherit the pre-established security posture without requiring per-namespace configuration. VCF Automation IaaS Resource Policies support a Kubernetes cluster baseline pod security level enforcement option, allowing administrators to require that provisioned clusters carry a baseline pod security posture as a provisioning condition. Kubernetes pod and container security contexts support defining Seccomp profiles, including the RuntimeDefault profile that provides a strong set of security defaults while preserving workload functionality, along with AppArmor policies and Linux capability restrictions. Individual Secrets and ConfigMaps can be marked as immutable through the ImmutableEphemeralVolumes feature gate, locking down configuration values after initial deployment so they cannot be changed without explicit action.

VCF's Image-Based Lifecycle Management and Configuration Profiles help maintain secure baselines across upgrades and reinstallation. When hosts are provisioned or upgraded, the desired configuration state is defined declaratively through host profiles and image specifications. Host profiles are standard configurations that can be applied to hosts on vCenter to simplify

operational management of large-scale environments. VMware recommends creating production images with the latest patches and required security settings that follow corporate security policies.

VCF Operations includes a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules through configurable enforcement options. This mechanism lets administrators apply and re-enforce the pre-established security configuration across hosts, supporting consistency after reinstallation or upgrade events. VCF Operations also provides compliance measurement capabilities, allowing organizations to monitor their infrastructure against optimum configurations and maintain a consistent configuration baseline across SDDC components. The Configuration Drifts feature detects deviations from assigned configuration template values, compares the current vCenter values against the configuration template values, and displays results in a dashboard where administrators can view and compare drifts and identify settings that have changed.

NSX components also ship with default profiles applied during installation. When a segment or segment port is created, it is initially assigned a Default Segment IP Discovery Profile with a predefined set of policies. Default segment profiles are applied to distributed port groups during Distributed Security installation and can later be switched to custom profiles to meet organizational requirements. This means NSX networking starts from a known secure state rather than requiring manual configuration from scratch.

VMware recommends that configuration decisions be tailored to individual customer environments rather than applying uniform standards across all deployments. The Security Configuration Guide and the DISA STIG for VCF components are the vendor's pre-established secure baseline.

Full responsibility for pre-established secure configurations as a vendor obligation extends beyond what VCF alone addresses. VCF provides the documented baselines, component-level hardening guides, lifecycle management tooling that carries secure configurations through upgrades, drift detection for identifying deviations, and enforcement workflows for reapplying secure settings. However, the organizational supply chain governance that requires vendors to deliver securely configured products, and the processes to verify and maintain those configurations across the full technology portfolio, are separate organizational concerns.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) ships with security controls enabled by default, reducing misconfiguration risk at initial deployment. PostgreSQL databases provisioned through DSM use scram-sha-256 as the default password authentication algorithm. The `pg_hba.conf` host-based authentication file includes default entries requiring scram-sha-256 for all database users, including a dedicated entry for the `pgadmin` administrative user. When restoring a PostgreSQL cluster to a different control plane, DSM recreates the host-based authentication configuration from a Kubernetes secret in the target namespace, carrying the access control rules forward through the restore operation. These secure authentication defaults are built into the database provisioning workflow rather than requiring post-deployment configuration.

DSM database clusters use TLS certificates for client connectivity and monitoring by default. In version 9.1, DSM's default certificate validation mode is "latest," which enforces strict cryptographic and KeyUsage validations for all endpoints, including the Provider VM and database service clusters. During initial configuration, DSM verifies the SHA256 thumbprint of VMware vCenter to confirm a secure connection before proceeding. Custom trusted certificates used in DSM must comply with FIPS requirements. Organizations upgrading to version 9.1 must review and replace existing certificates to conform with updated cryptographic algorithm requirements before the upgrade proceeds. Organizations with more restrictive PKI policies can replace the default DSM certificate with a custom certificate through the DSM UI while retaining the default security posture.

The Consumption Operator deployment includes Signature Verification validation to confirm package integrity during installation. An authentication secret containing the information needed to connect to the DSM provider is required as part of the Consumption Operator installation process. For SQL Server clusters, DSM establishes compute resources, software edition, and initial security configuration for each database instance at provisioning time. The Provider Appliance deployment requires compatibility checks to complete successfully before network configuration can proceed.

For ongoing maintenance, DSM provides update bundles for applying patches and upgrades. Kubernetes-native security configurations carry forward through version transitions, though organizations should verify that custom configurations such as custom certificates and host-based authentication rules persist as expected through each upgrade cycle.

TDA-02.4 also covers organizational procurement processes, vendor contractual requirements, and ongoing supplier management activities that operate outside the scope of any individual product's technical capabilities. Organizations deploying DSM must supplement these technical defaults with procurement policies that formalize expectations for secure configurations at delivery and across upgrade cycles.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer ships with several pre-established secure default configurations that address this control. SSL/TLS Profile Templates, accessible in the Security section of the Controller UI, define accepted cipher suites and protocol versions in prioritized order for virtual service encrypted communication. Any virtual service handling secure connections requires assignment of an SSL/TLS profile, with the Profile Templates as the defined starting point. The System-Secure-HTTP application profile is a pre-established configuration that secures HTTP traffic by enforcing HTTPS, protecting cookies, managing client IP handling, and controlling protocol behavior; it is available as a named default for L7 virtual services. Optimized SSL Certificate Chaining is enabled by default for new Avi Controller deployments, establishing a secure baseline without administrator intervention.

For Controller-to-Service Engine communication, secure channel certificates are configured through the System Settings administration panel (Administration > System Settings). The Controller uses System-Default-Secure-Channel-Cert as the default SSL key and certificate reference for this channel. In deployments integrating with Venafi Trust Protection Platform, all certificates are protected and controlled through that platform in a manner transparent to the Avi Load Balancer Controller; the Onboard Discovery feature automates importing existing certificates into the platform for monitoring, validation, and provisioning.

Avi includes pre-upgrade verification that checks whether secure configurations remain intact before any upgrade proceeds. Pre-upgrade checks verify that the Controller-to-Service Engine secure channel certificate has not expired and that certificate chain integrity is not weak. This verification runs before upgrade activity begins and is accessible through Administration > Update > System > VIEW PROGRESS in the Controller UI. In Avi for VCF deployments, post-upgrade validation requires that Avi Management Plane alarms, alerts, and dashboards are operational and that Controller licensing is valid and current.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) provides pre-established secure defaults including the System-Standard SSL Profile for SSL/TLS re-encryption to backend servers with modern cipher suites, the PKIProfile Custom Resource Definition for certificate-based authentication and encryption with backend services, and configurable pod security context settings applied to the AKO pod via the podSecurityContext tunable.

The organization must actively assign SSL/TLS profiles to each virtual service and verify that pre-established configurations remain in effect after each upgrade cycle. Profile Templates and system-level defaults are selectable starting points, not automatic assignments across all virtual service configurations, so administrators must apply and validate them following reinstallation or upgrade.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(c)

> ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them;

SCF Controls: TDA-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides structured update delivery mechanisms and notification capabilities that support ongoing product security for its infrastructure components, though full automatic update delivery and proactive notification to all affected users require additional organizational processes.

VCF uses a tiered release model for delivering security fixes. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations and can be applied selectively to individual components without requiring synchronized updates across the entire VCF stack. These patch releases are issued between major, minor, and maintenance releases to address urgent security concerns. Maintenance releases are scheduled, cumulative updates that include bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. For VMware ESX hosts specifically, software updates including patches of the ESX base image, partner add-ons, IOVP drivers, and VMware Tools updates are available through online depots. For deployments without direct internet access, the vSphere Lifecycle Manager's Update Manager Download Service (UMDS) can be configured to download patch binaries, patch metadata, and host notifications to a local repository and serve them as an offline update source.

VCF Operations provides lifecycle management capabilities that orchestrate the update process across VCF components, including ESX hosts, vCenter, and NSX. The lifecycle management workflow handles dependency ordering, pre-upgrade validation, and coordinated rollout so that security patches are applied consistently across the infrastructure. VCF Operations requires a precheck to succeed before scheduling component upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. However, updates are not applied automatically. An administrator must review available updates and initiate the update workflow.

For the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support a rolling update model for delivering security updates to cluster infrastructure. Updates are initiated by modifying the cluster specification, with VKS Controller updates encompassing supporting services such as the Container Networking Interface (CNI), Container Storage Interface (CSI), and Cloud Provider Interface (CPI) alongside configuration updates for the clusters themselves. This rolling update mechanism allows security patches to reach cluster infrastructure components in a controlled sequence without requiring full cluster downtime. At the workload level, Kubernetes Deployments support rolling updates that replace Pod instances incrementally, so security-patched container images can be deployed without interrupting running services. VCF Automation makes update and patch actions available to consumers through its self-service catalog, where day-2 actions including updates and patches can be initiated by the workload owner independently. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS releases, providing hardening guidance and defining baseline security configurations that inform operators of recommended configuration states.

The vCenter Patching API provides programmatic access to list available updates, run pre-check validations, and stage downloads. vCenter categorizes available updates with type labels including SECURITY and BUG FIX AND SECURITY, which administrators can use when reviewing available updates to prioritize security-specific patches. PowerCLI provides a Test-Compliance command that scans hosts and clusters against downloaded patches to identify what needs remediation. These tools allow administrators to integrate patch status checks into their operational workflows.

VCF includes several notification and detection mechanisms for security updates. VCF Operations components receive security-related updates in the form of VMware Security Advisories (VMSAs), which are the primary notification mechanism for available security patches. Emergency updates are released for VCF Operations integrations in response to system

degradation issues or security bulletins. VCF Operations provides advance notice of urgent interoperability and security updates at 72-hour and 24-hour intervals before the update becomes available. VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack by cross-referencing the installed versions against published VMSAs, surfacing the exposure with a description, root cause insight, and actionable remediation steps.

For container workloads on VKS clusters, Harbor Registry, available as a Supervisor Service, provides vulnerability scanning of stored container images and content trust controls to restrict the use of unscanned or untrusted images. This gives operators visibility into images that carry known vulnerabilities, informing decisions about which images require patching or replacement. The Prometheus standard package, installable on VKS clusters, deploys Prometheus and Alertmanager in the `tanzu-system-monitoring` namespace. Alertmanager receives alerts from Prometheus via HTTP and routes them to external notification channels including email and webhooks, supporting organizational workflows for notifying teams of conditions related to cluster health or component version thresholds. The AlertmanagerConfig custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external systems. For GitOps-driven environments, the ArgoCD Supervisor Service supports a notification controller that can be enabled via the `notification.enabled` configuration setting, allowing operators to receive alerts when application sync states change or when cluster state drifts from the desired configuration defined in a repository.

VCF also includes configurable notification capabilities that administrators can use for operational awareness. VMware vCenter can send email notifications and SNMP traps when alarms are triggered, with configurable recipient addresses. VCF Operations supports outbound SNMP trap notifications to external management systems, with up to four configurable trap destinations. While these notification mechanisms are designed for operational alerting rather than update notification specifically, they form part of the broader monitoring infrastructure that administrators use to maintain awareness of environment status.

These capabilities cover VCF infrastructure components and the Kubernetes consumption layer rather than all technology assets in the environment. Patching guest workloads and applications running on VCF, and maintaining container images with current security patches, remain the responsibility of the workload owners. The organization is responsible for subscribing to VMware Security Advisories, monitoring for new patches, evaluating applicability, and scheduling update windows according to change management processes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports update delivery through a configurable Maintenance Policy and an integrated upgrade management interface. The Maintenance Policy, set from the vSphere Client by a vSphere Administrator, allows administrators to schedule automatic software updates for DSM appliances and define the duration window during which updates are applied. Administrators configure a future date and time for the policy, giving organizations control over when DSM platform components are updated while reducing the manual coordination required to keep the platform current. When automatic plug-in updates fail, DSM recommends manual software updates of appliances as a fallback path.

DSM provides update discovery through a "Check for Upgrade" function, accessible in the Version & Upgrade section of the DSM UI via the DSM System tab. This function queries for available updates and displays them in the Available Upgrades table. Update bundles can be uploaded from a remote server URL with credentials or from a local file, giving administrators flexibility in sourcing release packages. Updates follow a staged progression: after a release bundle is uploaded, it transitions to a Ready to Install state before being applied during the configured maintenance window. The Version & Upgrade management interface allows administrators to track plug-in versions, release dates, and activation states.

DSM extends automatic upgrade coverage to managed databases. Administrators and users can activate automatic database upgrades by specifying a maintenance window for each data service. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, providing a mechanism for applying security-relevant patches to database instances on a defined schedule.

DSM adds SQL Server as a supported managed database type. SQL Server instances in DSM follow the Cumulative Update (CU) branch, which contains the complete set of functional, performance, and security updates for the major version, keeping SQL Server databases provisioned through DSM current with security-relevant patches as part of the standard update track.

DSM supports webhook notifications that can route system alerts to external destinations such as email, Slack channels, or ServiceNow. While these notification capabilities address operational events rather than dedicated security update announcements, they provide notification infrastructure that organizations can incorporate into update communication workflows.

Applying DSM plug-in updates requires administrators to upload release bundles and configure Maintenance Policies before automatic updates can apply. DSM does not natively send proactive notifications about available security updates to all affected users; that communication step depends on organizational processes outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) 9.1 supports security update notification through its event alerting framework and delivers automatic updates for certificate material and live security threat intelligence content.

The Avi Controller includes a configurable event alerting framework supporting four notification destinations: the local UI (displayed as colored bell icons), email, syslog, and SNMP v2c and SNMPv3 traps. Notification profiles are configured in the Operations > Notifications page. Alert configurations trigger on system events and route to one or more destinations, and can carry security-relevant notifications including conditions that signal a need for patching. SNMP notification transport can be configured with TLS encryption and strict certificate verification enabled.

For certificate-based security material, the Controller applies automatic updates. When a certificate held by the Avi Controller is updated through manual replacement, Let's Encrypt integration, or Venafi Trust Protection Platform integration, the updated certificate is automatically and transparently pushed to all Service Engines using that certificate. This propagation occurs without service interruption and without requiring separate operator action on each Service Engine. The Venafi Onboard Discovery feature automates importing certificates into Trust Protection Platform, where they can be monitored, validated, and provisioned, and Trust Protection Platform automatically handles certificate and chain certificate renewals based on the mapping of virtual service names to certificates.

Avi also introduces Live Security Threat Intelligence through the Avi Cloud Console, which provides automatic synchronization of security content to enabled deployments. The Application Rules service provides automatic synchronization of the Application Rules Database, delivering current application vulnerability protection rules without manual action. The Bot Management service includes a User Agent Database Sync capability that receives current User-Agent updates for threat detection. The IP Reputation service maintains a real-time, up-to-date security posture across globally distributed Avi Controller clusters by delivering current threat feed data automatically.

Avi WAF Enterprise license customers receive OWASP Core Rule Set (CRS) updates through the customer portal. These updates are available for download and are applied by administrators.

Software upgrade and patch operations for the Controller and Service Engine groups are administrator-initiated. During the term of a purchased subscription, customers have access to new software releases including software patches published by Broadcom for Avi Load Balancer and 24/7 support. The /api/upgrade REST API endpoint supports applying a base image, a Controller patch, and a Service Engine patch in a single operation. Upgrade, patch upgrade, rollback, and rollback patch operations are all supported. Virtual service disruption must be assessed and communicated before upgrade operations. In VCF deployments, Avi Management Plane alarms, alerts, and dashboards must be verified as operational as part of post-upgrade validation.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(d)

> ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access;

SCF Controls: TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(e)

> protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means;

SCF Controls: TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(f)

> protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions;

SCF Controls: TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(g)

> process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation);

SCF Controls: DCH-01.2, DCH-01.4, IAC-21, PRI-05.4

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces least privilege through a granular role-based access control (RBAC) model that spans all major platform components. Permissions are scoped both by function and by inventory location, so users can perform only the activities specified by the role assigned to them on the specific object to which that role is assigned.

VMware vCenter implements a privilege model where privileges are system-defined requirements associated with vSphere managed objects. These privileges are defined by VMware and cannot be changed by client applications, which means the privilege boundaries are enforced at the platform level. Privileges are fine-grained access controls that can be grouped into roles, providing precise control over what actions each user can perform. Users are granted access through roles, which are predefined sets of privileges mapped to users or groups on specific objects.

vCenter ships with several built-in roles that enforce varying levels of access restriction. The three permanent system roles, Administrator, Read Only, and No Access, cannot be deleted or edited; new users and groups are assigned the No Access role by default, so access must be explicitly granted before a user can view or change any object. The Read Only role grants only three system-defined privileges: System.Anonymous, System.View, and System.Read. The Operator role is the most restricted authorization level available, allowing users to view information about vCenter but not alter its configuration. For cryptographic operations, a dedicated No Cryptography Administrator role provides all Administrator privileges except Cryptographic Operations, so that only users explicitly assigned the Cryptographic Operations privileges can perform encryption-related tasks. If a predefined role does not meet specific needs, administrators can create custom roles containing only the minimum set of required privileges. For users who require administrative access to virtual machine configuration but should not be able to run commands inside a guest operating system, the platform supports creating a custom role that excludes the Virtual machine > Guest operations privilege.

vCenter also provides a privilege check recording feature that monitors which privileges are checked during vCenter operations. The PrivilegeChecks service interface provides operations for retrieving a list of the latest privilege checks along with the corresponding sessions, users, managed objects, and operation IDs. Administrators can use this capability to identify which privileges are actually exercised during a workflow and build roles with only the minimum privileges needed for specific operations.

VCF Operations implements its own RBAC system where users can only perform the actions that their permissions allow. The ReadOnly role provides read-only access, allowing users to perform read operations but restricting write actions such as create, update, or delete. The VCF Operations documentation recommends that the administrators role be assigned only to specific users who must access objects and perform actions across the entire environment. Local VCF Operations users and vCenter users should be configured with the specific privileges required for their role to avoid unexpected access from overly permissive role assignments. Even integration adapters follow least privilege principles: the Management Pack for Oracle Database, for example, requires creation of a least-privileged user with minimum database user privileges. The Management Pack for Kubernetes similarly requires that user-defined custom roles provide read-only access to all cluster resources and the Kubernetes API.

VCF Automation supports organization-specific roles that can be assigned only to users within the organization to which they belong. Organization users can use only those rights from their roles that are published to their organizations. Organization administrators can create custom roles to grant selected users permissions to perform specific tasks or access content outside of their default organization roles, enabling precise scoping of access. System administrators manage access to projects and catalog items through entitlement policies using user criteria, providing another layer of access control that restricts what

resources users can request and consume. The `cloud_admin` service role satisfies the minimum service role requirement for VCF Automation API access, and the `Cloudadmin` role provides host switch-level permissions within VCF Automation.

At the Consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor implement two complementary tiers of least privilege: namespace-level permissions and Kubernetes RBAC within clusters. vSphere Namespace permissions for VCF SSO users and groups are assigned through three roles: Can View (read-only access to VKS cluster objects provisioned in the namespace, with no permissions mapped to Kubernetes roles within those clusters), Can Edit (modification rights), and Owner (full administrative control). The VCF Consumption CLI enforces these role assignments at the API boundary; VCF SSO users who lack sufficient permissions on a vSphere Namespace receive an "Error from server (Forbidden)" response and cannot connect to Supervisor or VKS clusters. Administrative operations on Supervisor Services require a discrete "Manage Supervisor Services" privilege on VMware vCenter, scoped separately from general vSphere Administrator access. Content library administration similarly requires specific permissions beyond the vSphere Administrator role, with individual permissions assignable through custom roles when the full Administrator role is not appropriate.

Within VKS clusters, Kubernetes RBAC provides fine-grained access control through Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings. RBAC rules are expressed in terms of specific resource types and verbs (get, list, create, delete, and so on), with guidance that specific resources and verbs be used rather than wildcard entries, so only the permissions required for a workload to function correctly are applied. Platform Operators and DevOps users are assigned non-admin or custom roles scoped to their responsibilities; Developer users receive read-only or no roles by default. Kubernetes RBAC supports least privilege for ServiceAccounts as well: by creating ServiceAccounts with narrow RBAC bindings and attaching them to workloads, pods operate with only the permissions they require rather than inheriting broad cluster-level access. Separating ServiceAccount creation from human user onboarding makes it practical to maintain least privilege for automated workloads independently of human access management. RBAC should be used to enforce least-privilege access to Secret objects specifically, given the sensitive nature of credential material. Administrators can use `kubectl auth can-i` with user impersonation to verify what actions other users can perform, supporting least privilege verification without requiring direct credential access. IAM role trust policies in the Consumption layer should be scoped to specific service accounts and namespaces to enforce least privilege boundaries at the identity-to-workload level. Kubernetes RBAC enforces binding constraints: a user creating or updating a RoleBinding or ClusterRoleBinding can only grant permissions they themselves hold, and a user creating or updating a Role or ClusterRole cannot add permissions beyond their own. Where limited delegation is needed, the `bind` verb can be scoped to specific named roles, so administrators cannot delegate access beyond what they are themselves authorized to grant. Periodic review of RBAC settings for redundant entries and potential escalation paths supports ongoing least-privilege hygiene.

VKS clusters apply least privilege at the workload level through Pod Security Admission (PSA). PSA supports three profiles: Privileged (unrestricted, permits known privilege escalations), Baseline (minimally restrictive, blocks known privilege escalation vectors while allowing the default minimal pod configuration), and Restricted (a hardened profile that follows least privilege, requiring non-root execution and restricting Linux capabilities). The Restricted profile is the recommended target for workloads that should operate with least privilege. Kubernetes also allows granting specific Linux capabilities to a container process without granting all privileges of the root user, enabling capability-level access scoping for workloads that require specific kernel permissions without full privilege. The Supervisor secret injection agent runs with `allowPrivilegeEscalation` set to false, blocking privilege escalation at the platform component level. Cluster administrators should understand privilege escalation paths introduced by create and update permissions on workloads that can reference arbitrary ServiceAccounts, and should restrict those permissions accordingly.

Centralized authentication through VCF SSO means that privilege assignments are consistently enforced across vCenter, VMware ESX, NSX, and VCF Operations. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and supports single sign-on to enable secure user login.

The platform documentation explicitly recommends that user accounts be given the minimal number of privileges required to perform their assigned tasks. When predefined roles are too permissive for a given use case, custom roles should be created containing only the minimum set of required privileges. For Kubernetes environments, administrators are directed to use a least-privileged `kubeconfig` for routine operations and to reserve break-glass access only for emergency situations.

VMware Private AI Services (PAIS) supports the concept of least privilege through a layered set of access controls that scope permissions to specific roles, groups, and project membership across the AI platform.

PAIS access is controlled through OIDC group-based authorization. The `authorizedGroups` configuration specifies which OIDC groups may access PAIS endpoints, and only user accounts that are members of those groups can reach the service. The same model applies whether activation is performed through the VCF Automation UI (via the `oidc-authorized-groups` setting) or through `kubectl`. PAIS activation requires coordination with the OIDC provider administrator to define identity and access management before users can be granted access.

Access to AI catalog items in VCF Automation is gated by explicit permission grants. DevOps engineers and other consumers must receive permission from an organization administrator before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters or deep learning VM catalog items. When importing PAIS namespaces from VMware VCF Automation 8.18 into VCF Automation, users with the Project Viewer role must be reassigned the Project Auditor role, scoping read-only access to the new tenancy model.

For ML model storage in Harbor, PAIS scopes access at the project level. Harbor project read-write permissions are required to store models, restricting access to sensitive training and tuning data by Harbor project role. Only users with assigned project roles can push or pull model artifacts.

Role assignment for AI workload deployment is explicit and requires an authorized administrator. The organization administrator must assign the required user role before users can deploy deep learning VMs, and VI administrators must have appropriate permissions on the underlying vSphere cluster to deploy DL VM templates. VCF Automation uses separate scoped tokens for provider-level and tenant-level operations: a `PROVIDER_ADMIN_ACCESS_TOKEN` for provider scope and a `TENANT_ADMIN_ACCESS_TOKEN` for organization administrator scope, keeping administrative privileges partitioned by function.

The Grafana observability layer for PAIS supports role-based access through OIDC group mapping. The `grafana-oidc-role-mapping` configuration assigns the Admin role to users matching a designated OIDC group attribute and the Viewer role to other authenticated users, scoping write access to the observability platform to a named administrator group.

Deep Learning VM deployment uses restricted cloud-init file permissions to control access to initialization and workload execution code, with executable permissions (0755) for application scripts and restricted permissions (0600) for network configuration files. When configuring external data sources for Knowledge Bases, PAIS specifies that the integration service account should be created with no assigned roles as its starting state, and Google Drive folders used as data sources must be shared with the service account using view-only permissions.

Tenant isolation extends to compute allocation: organization region quotas in PAIS can be assigned from single or multiple supervisors, with CPU and memory limits and reservations configured per zone, scoping resource consumption to the limits set by the provider administrator.

VMware vDefend (Contributes)

VMware vDefend implements the principle of least privilege at two levels: network access control for workloads and role-based access control for its own administrative interfaces.

At the network layer, the vDefend distributed firewall (DFW) restricts workload-to-workload communication to only those flows explicitly permitted by policy. Default-deny rule bases mean no network path is open unless a rule specifically allows it. Microsegmentation policies can be scoped to individual workloads, security groups, or application tiers, so each workload receives only the network access required to function. Governance guidance in the 9.1 documentation advises administrators to avoid overly permissive rules such as "ANY/ANY/ANY ALLOW" and to define rules that permit only the specific protocols, ports, and source-destination pairs each application needs.

A new capability in 9.1, Privileged Labels, strengthens workload-level least privilege by anchoring firewall rules to immutable, organization-defined labels that namespace users cannot remove from virtual machines. This mechanism keeps workloads within their assigned security groups so they remain subject to the applicable firewall policies regardless of attempts by lower-privileged namespace users to move them out of scope.

For administrative access to vDefend itself, Security Services Platform (SSP) enforces role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Role permissions are differentiated by operation: the Enterprise Admin role holds Full Access (FA) to deploy, manage, upgrade, configure authentication and authorization, perform server configuration, and activate Security Intelligence for SSP. The Security Operator role holds Restricted (R) permissions covering Security Intelligence data collection configuration, infrastructure and environment monitoring, and segmentation policy publication, without access to service activation or administrative configuration. Enterprise Administrator privileges are specifically required for high-privilege operations including activating the Malware Prevention Service, deleting Malware Prevention Service features, and accessing User Management to modify role assignments. Administrative privileges are also required to administer compute entity classifications in Security Intelligence. The same five-role structure governs Security Intelligence and Rule Analysis operations within SSP, with each role receiving only the permissions appropriate to its function.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements least privilege across its two primary user roles: Admin and User. The separation is enforced at the platform level and reflected throughout the console interface.

Users assigned to the DSM User role can view and manage only the database objects they own. They cannot access or modify objects belonging to other users or manage platform-wide configuration. The DSM console restricts the views and actions available based on the assigned role, so User-role accounts see only the subset of the interface relevant to their scope. Administrators have access to the full environment and can create, monitor, and manage all data services, but this elevated scope is reserved for accounts explicitly assigned to the Admin role.

User and role management is performed through the vSphere Client Permissions interface under the Data Services Manager Configure tab. Administrators can create local users through the DSM UI and assign namespace access through the Permissions view. DSM also supports LDAPS-sourced identities, allowing organizations to map directory service groups to DSM roles and manage access centrally. DSM clears the VMware vCenter administrator credentials secret after successful registration, limiting credential exposure during the initial configuration process.

DSM applies least privilege at the database level across all supported database engines. PostgreSQL database instances support the GRANT command to assign specific privileges on databases and schemas to individual database users. LDAPS-authenticated PostgreSQL users can be granted specific privileges, including database-level and schema-level access, through explicit GRANT assignments. MySQL LDAPS-authenticated users can be granted specific privileges using the GRANT command to restrict access to designated databases. The default MySQL database user is not a MySQL superuser; it is granted a defined set of privileges for data and schema operations, limiting access to what is required for typical database management. Only the database owner can perform administrator password changes on a given instance, restricting credential management to the party responsible for that database.

For SQL Server instances, DSM creates a cluster administrator login that does not receive full sysadmin privileges. Instead, DSM grants this login restricted server-level privileges for server management and auditing operations, such as the ability to alter connections and view server state. DSM maintains a separate `dsm_mgmt` internal management login that restricts user access to system-level objects, keeping administrative operations within an isolated context. SQL Server instance provisioning and server-level configuration management, including Active Directory integration and high availability settings, is restricted to DSM administrators only.

VCF Automation namespaces that are externally managed in DSM are treated as read-only, restricting modifications to objects whose lifecycle is governed outside DSM. Infrastructure policy configuration requires that the responsible administrator hold the appropriate DSM permissions. These constraints limit what each actor in the system can modify based on their role and the ownership of the resources involved.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides native role-based access control (RBAC) at the Avi Controller level, covering administrative access to all Avi-managed resources including virtual services, pools, application profiles, certificates, and GSLB configuration. The RBAC framework supports four access types per resource: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), No Access (complete exclusion, including inability to read or list the resource), and Assorted (a mixture of different privilege levels for different resources within a system area). These types are assigned per resource, so a given role can combine read-only access to some areas with full write access to others. The Avi Controller enforces these constraints at runtime; users can access resources only to the extent their assigned role permits.

When predefined privilege levels do not match the access needs of a particular user account, the Avi Controller supports custom role creation. Administrators create roles that specify a targeted combination of write, read, no-access, or assorted permissions for each resource area. This is configured in the Avi Controller UI under User Authentication and Authorization > User Roles. The Avi documentation recommends creating custom users and roles with limited privileges when the use case does not require System-admin or admin access, rather than assigning broad administrative rights.

The Extended Granular RBAC feature adds label-based scoping to access control. The `allow_unlabelled_access` parameter on a role object controls whether users assigned that role can see resources that have not been tagged with labels, enabling

access to be scoped to specific application groups or object subsets rather than the entire Controller inventory. Certain permissions classified under Operations and Administration are not supported for role-based access control per application using labels; those must be managed at the global role level. For Auth Mapping Profile configurations, the role and tenant configured for the Any Group or Any Attribute rule should be set to least privilege, as the least-privileged access takes effect after login when no specific group match exists.

Certificate and key management access is subject to RBAC restrictions. The Avi Controller documentation specifies that the ability to export certificates and keys must be restricted to the fewest number of administrators possible using role-based access control. Write access to Virtual Service, Application Profile, SSL/TLS Certificates, and Certificate Management Profile objects can be scoped to specific roles without granting broader administrative rights.

GSLB administration is covered separately within Avi's RBAC. Roles can be created that grant write access only to GSLB service resources without providing broader Controller-level access. For GSLB scenarios that do not require System-admin or admin user privileges, Avi's documentation recommends creating a custom user and role with limited permissions rather than assigning the full System-Admin role. Avi GSLB supports creation of non-admin users with assigned roles for granular access control.

In VCF deployments using organization-managed mode, Avi Load Balancer applies a tiered administrative model. The Provider or Load Balancer Administrator manages resource assignments to organizations and enforces quotas and resource boundaries. An organization administrator must be logged in to edit a Service Engine Group. Project Administrators can deploy and manage load balancing for their applications without waiting for organization administrator intervention, while being restricted from altering Service Engine Group properties such as capacity and placement. This model maps load balancing management authority to the appropriate organizational scope.

At the integration boundary with VMware vCenter, the Avi Cloud Connector uses a vCenter user account that must have only the minimal set of permissions Avi requires. Two roles must be created for the vCenter Cloud Connector integration: one with global privileges (Avi-Global-Role) and another with folder-level privileges (Avi-Folder-Role). The Avi-Global-Role must be assigned with the Propagate to children option selected to apply permissions to all child objects. The vCenter account user must be assigned the Avi-Folder-Role to the folders containing Service Engine VMs in the vCenter inventory. vCenter cloud access modes include no-access (Avi Controller has no access to vCenter resources), read-access (integration with read-only access), and write-access (full automation of Service Engine creation and placement), allowing deployments to operate with the minimum vCenter access level needed for the deployment scenario.

Least privilege for the compute, storage, and network fabric underlying the Avi Controller and Service Engine virtual machines is a VCF platform responsibility. Organizations must design Avi role assignments that correspond to job functions and apply them to user accounts for this control to take full effect across the environment.

Control Annex I Part I (2)(h)

> protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks;

SCF Controls: TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(i)

> minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks;

SCF Controls: TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(j)

> be designed, developed and produced to limit attack surfaces, including external interfaces;

SCF Controls: TDA-02.8

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that help organizations reduce the attack surface of their virtualized infrastructure, though a complete attack surface minimization program requires organizational processes and tooling beyond what the platform itself delivers.

VCF Operations tracks security advisories and available updates for all VCF components, alerting administrators when patches or fixes are available. VCF's patch management architecture supports selective, component-level patching. Patch releases deliver time-sensitive fixes to security issues and can be applied to individual components without requiring synchronized updates across all VCF components. This design allows organizations to respond quickly to newly disclosed vulnerabilities without the overhead of a full-stack upgrade cycle. Lifecycle management automates the process of applying updates across ESX hosts, vCenter, NSX, and other stack components, reducing the window during which known vulnerabilities remain unpatched. VMware publishes security advisories (VMSAs) for critical known vulnerabilities across VCF components, including VCF Operations and VCF Operations for Networks, with step-by-step remediation instructions. Keeping components at their latest versions is recommended to take advantage of all available security fixes.

VCF includes a security compliance engine that can discover objects across the environment that are not compliant with a defined security standard. The platform supports compliance checking against the Security Configuration Guide and the DISA STIG, giving operators a systematic way to assess and remediate hardening gaps across VCF components. Built-in compliance checks report objects that are not compliant with these hardening standards, allowing administrators to identify and address configuration weaknesses. vCenter also supports user-defined security baselines, allowing security administrators to define custom security standards and compare both ESX hosts and virtual machines against those baselines to identify and remediate deviations.

Configuration Profiles and Image-Based Lifecycle Management allow administrators to define a desired host configuration baseline and detect drift from that baseline. When hosts deviate from the approved configuration, drift detection flags the change so administrators can remediate it. This helps prevent configuration sprawl that can introduce new attack surface.

ESX host hardening is a core element of attack surface reduction within VCF. Recommended hardening steps include configuring authentication and authorization settings, disabling unnecessary services, enabling Secure Boot and Trusted Platform Module (TPM) support, and implementing network security measures. These measures collectively reduce the number of exposed services and entry points on each host.

The Consumption layer, delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor, provides additional attack surface minimization mechanisms for containerized workloads. Pod Security Admission (PSA) enforces security constraints across namespaces using Baseline, Restricted, and Privileged profiles; the Baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads, while the Restricted profile drops all Linux capabilities by default, directly reducing the OS-level attack surface available to container processes. Security contexts within pod specifications allow operators to restrict OS-level privileges on individual workloads. AppArmor and SELinux profiles applied through security context annotations restrict what container processes can access beyond the capability set, helping mitigate container runtime vulnerabilities. Seccomp profiles can reduce the Linux kernel syscall attack surface available inside containers by creating allow or deny lists of specific syscalls using BPF-named profiles. User namespaces map container root user IDs to unprivileged host UIDs, limiting potential damage from container breakout scenarios. Security Technical Implementation Guides (STIGs) for VKS system components, including Supervisor and VKS Releases (VKRs), are available to guide administrators through security-relevant configuration choices for the Consumption platform layer, and the vSphere Supervisor platform builds on vSphere security features in VMware vCenter and VMware ESX to provision workload clusters that are designed to be secure by default. Harbor Registry, available as a Supervisor service

package, provides vulnerability scanning, content trust, and policy-based access control for container artifacts, supporting limits on the introduction of known-vulnerable components into running workloads. The Consumption layer also supports integration with Harness Security Testing Orchestration, which scans container images across each layer and deduplicates vulnerability findings, presenting each unique issue as a single actionable item for development teams to address before workloads are promoted to production. Virtual machine images deployed through vSphere Supervisor should be built with the latest patches and required security settings following corporate security policies for production environments.

Network architecture within VCF contributes to attack surface reduction. In secure environments, the Workload Separation Distributed Switch Model provides physical air-gapped separation of network traffic, limiting lateral movement paths. NSX segment security filters traffic to protect segment integrity, and NSX Context Profiles and vDefend L7 Access Profiles provide application-layer traffic filtering. Security groups and security policies can be defined within NSX to enforce network-level isolation and access controls across the virtual environment. At the Kubernetes workload layer, network policies enforced through Antrea CNI restrict ingress and egress traffic at the namespace level, limiting lateral movement between workloads and reducing the scope of what a single compromised workload can reach. Service meshes, where deployed, extend this with Layer 7 workload-identity-based policies and mutual TLS for inter-service communication, further scoping traffic to declared service relationships.

VMware's internal security team maintains controls to minimize the security footprint of VCF components such as VCF Operations for Networks, reflecting a secure-by-design approach to the platform's own development and release process. VCF Operations for Networks is hardened against industry-accepted security benchmarks.

These capabilities provide the technical foundation for attack surface minimization, but the control also requires organizational vulnerability management processes, risk-based prioritization of remediation efforts, and regular assessment cycles that fall outside VCF's scope as an infrastructure platform. Minimizing the attack surface across all customer-deployed workloads and applications running on VCF requires additional organizational processes and tools beyond what VCF provides natively. For Kubernetes workloads on VKS, STIG hardening must be applied during cluster provisioning and validated periodically, security contexts must be configured in workload specifications, PSA enforcement modes must be set appropriately per namespace, and image scanning through Harbor must be integrated into deployment workflows consistently rather than treated as a one-time step.

VMware Private AI Services (PAIS) provides several AI-specific mechanisms that help reduce the attack surface of AI workloads, model artifacts, and AI catalog items.

The Model Gallery workflow includes organizational validation of ML models before they are made available to AI application developers. MLOps engineers validate models against the organization's security, privacy, and technical requirements before upload, evaluate model performance and safety by examining inference requests for malicious behavior, and perform hands-on functional tests before deployment. PAIS guidance recommends distributing models within the organization that have been validated on a deep learning VM rather than models pulled from the Internet, which could contain malicious code or be tuned for malicious behavior. The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models, limiting which identities can read or modify model content.

PAIS uses a CA trust bundle for secure communication with external services and databases, scoping outbound connectivity to authenticated, encrypted channels. Remote Model Context Protocol (MCP) servers connected to PAIS can optionally use static authentication tokens, restricting which clients can invoke remote tool capabilities. Custom forms in PAIS blueprints can be modified to control user inputs at request time, allowing tenants to constrain the parameters passed to AI catalog items before they are provisioned.

Broader vulnerability management activities, including patch management, vulnerability assessment of underlying infrastructure, and risk prioritization, remain outside PAIS's direct scope and depend on organizational processes together with the platform layers that host PAIS.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to minimizing attack surfaces through network-layer virtual patching, microsegmentation, and threat analysis capabilities.

The vDefend distributed firewall (DFW) enforces microsegmentation policies on virtualized workloads, isolating critical services to reduce their network-accessible attack surface and restricting lateral threat movement. The Security Services Platform identifies vulnerable workloads that could be exploited for lateral movement and provides network and transport layer protocol validation against low-level IP attacks.

The vDefend IDS/IPS engine uses knowledge-based signature rules that match patterns corresponding to known attack types, detecting and blocking network traffic associated with known exploitable vulnerabilities. Administrators can search and filter signatures by specific CVE identifiers and by attack target (client or server) to tune detection to the asset types in their environment. Security profiles allow selection of specific system signatures and custom signatures; custom signatures can be added for custom applications and zero-day vulnerabilities beyond the built-in library. The IDS/IPS also detects obsolete protocols through port verification and application identification, enabling operators to identify deprecated communication methods in active use. When a signature triggers, vDefend IDS/IPS and Malware Prevention automatically export PCAP files for forensic analysis of captured network traffic. The Gateway Firewall with Advanced Threat Prevention supports Cloud Sandboxing and Artifact Analysis for north-south traffic flows. Advanced Threat Prevention features including IDS, Network Traffic Analysis, and Network Detection and Response are operable in air-gapped environments.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and traffic flows. These reports provide recommendations for applying DFW capabilities, presented as Projects that guide organizations through a staged Zero Trust journey from initial assessment to application-level microsegmentation.

Vulnerability remediation at the host and application layer, such as patching operating systems or application code, remains outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to attack surface minimization through network isolation controls, resource access restrictions, secure communications, and a structured patching mechanism. Full coverage of this control requires organizational processes and platform-level capabilities beyond DSM's own scope.

DSM's architecture requires VDS and N-VDS port groups to segregate database traffic from other network segments. Infrastructure policies, configured by vSphere administrators, establish limits and guardrails on the compute, memory, storage, and IP resources that DSM users can consume from vSphere clusters. These policies scope each user's access to a defined set of infrastructure components, reducing the potential blast radius of a compromised account or misconfiguration. IP pools define the address ranges assigned to database instances, and DSM detects network overlap between infrastructure policy IP ranges and system configuration networks, generating alerts and requiring that overlap to be resolved before provisioning proceeds. This validation step helps catch misconfigurations that could otherwise allow unintended network access between database tenants or between DSM-managed workloads and management networks.

When deployed in network-isolated environments, the DSM appliance bundles all necessary consumption operator artifacts locally, supporting air-gapped configurations where internet access is not available. Data service policies can be enforced consistently across different tenants, maintaining a uniform security posture regardless of who provisions a database.

DSM supports LDAPS for directory service connections, channeling administrator and user authentication over an encrypted connection. Connections to the DSM Provider VM are secured using TLS, with the Provider VM's certificate authority added to the trusted CA list. DSM verifies the SHA256 thumbprint of VMware vCenter during configuration, reducing the risk of connecting to an unauthorized or compromised vCenter instance. Database cluster connections use TLS for all supported database engines, including SQL Server, and the DSM UI provides a direct method to retrieve the CA certificate needed to establish those secure connections. These controls reduce the attack surface exposed by unencrypted management and application traffic.

The DSM Consumption Operator deployment includes Signature Verification validation to confirm package integrity before installation, reducing supply chain risk for managed workloads. DSM supports structured software update bundles for appliances and the DSM plug-in. The update mechanism requires at least one attempt to complete a chain of software updates, irrespective of the configured update window, supporting consistent application of security patches. Administrators

should apply available update bundles promptly to address known vulnerabilities in DSM components. The DSM UI also surfaces a compliance tab on data service policies, giving administrators visibility into policy adherence across managed databases.

DSM does not provide its own vulnerability scanning, intrusion detection, or firewall controls. Attack surface minimization at the platform level, including VMware ESX hardening, network segmentation, and vCenter access controls, is provided by the underlying VCF infrastructure. Organizations must maintain a vulnerability management program that identifies, prioritizes, and tracks remediation of known vulnerabilities across DSM and its supporting platform. Patch scheduling, testing procedures, and emergency response processes remain organizational responsibilities that DSM supports but does not replace.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that address attack surface minimization for applications it fronts.

WAF Application Rules are the primary mechanism for mitigating known exploitable vulnerabilities. These rules are specifically designed to block attacks on known application vulnerabilities, including those tracked as Common Vulnerabilities and Exposures (CVEs). Application Rules are automatically updated through Avi Load Balancer Cloud Services, so newly disclosed vulnerabilities can be addressed at the WAF layer without redeploying or modifying the underlying application. WAF signatures include detection for OWASP Top 10 attack vectors to maintain broad coverage across the attack surface.

In 9.1, the Live Security Threat Intelligence service, available through the Avi Cloud Console, delivers real-time security threat feeds covering various attack vectors for enabled Avi Load Balancer deployments. This feed complements the Application Rules with continuously updated threat intelligence, providing protection against evolving threats without manual rule updates.

Avi WAF supports a Positive Security model that reduces the attack surface from a complementary direction: rather than detecting known attack patterns, the Positive Security model restricts traffic to known-good application behavior through an allowlist built from sampled observed traffic. WAF policies should be configured to enable Positive Security protection using this traffic profile, which is maintained through the WAF allowlist sampling process.

For application teams using dynamic application security testing (DAST), Avi supports virtual patching through the Avi Load Balancer SDK, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning. DAST scanner results can be imported to identify and protect against potential security issues in applications before a code-level fix is available, reducing the window of exposure between discovery and remediation.

The Avi Kubernetes Operator (AKO) provides WAF integration for application-layer security in VMware Kubernetes Service (VKS) environments, extending attack surface minimization capabilities to Kubernetes-hosted workloads in Avi-for-VCF deployments.

Network-layer controls supplement the WAF layer. Network Security Policies block traffic from known-bad IP addresses by dropping TCP SYN packets before connections are established. The Avi Service Engine detects and mitigates a range of Layer 4 through Layer 7 network attacks, including IP fragmentation attacks, TCP SYN floods, HTTP SlowLoris attacks, and request floods. The Service Engine's data-plane architecture isolates attacks to the data plane, reducing the risk of impact to management interfaces. Configurable DDoS attack limits per application profile allow thresholds to be tuned to each application's expected traffic patterns. The Avi security penalty component monitors and reports active DoS attacks and SSL configuration vulnerabilities, providing visibility into the current threat posture.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control Annex I Part I (2)(k)

> be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques;

SCF Controls: TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part I (2)(I)

> provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (1)

> identify and document vulnerabilities and components contained in products with digital elements, including by drawing up a software bill of materials in a commonly used and machine-readable format covering at the very least the top-level dependencies of the products;

SCF Controls: TDA-04.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (2)

> in relation to the risks posed to products with digital elements, address and remediate vulnerabilities without delay, including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;

SCF Controls: TDA-01.1, TDA-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides structured update delivery mechanisms and notification capabilities that support ongoing product security for its infrastructure components, though full automatic update delivery and proactive notification to all affected users require additional organizational processes.

VCF uses a tiered release model for delivering security fixes. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations and can be applied selectively to individual components without requiring synchronized updates across the entire VCF stack. These patch releases are issued between major, minor, and maintenance releases to address urgent security concerns. Maintenance releases are scheduled, cumulative updates that include bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. For VMware ESX hosts specifically, software updates including patches of the ESX base image, partner add-ons, IOVP drivers, and VMware Tools updates are available through online depots. For deployments without direct internet access, the vSphere Lifecycle Manager's Update Manager Download Service (UMDS) can be configured to download patch binaries, patch metadata, and host notifications to a local repository and serve them as an offline update source.

VCF Operations provides lifecycle management capabilities that orchestrate the update process across VCF components, including ESX hosts, vCenter, and NSX. The lifecycle management workflow handles dependency ordering, pre-upgrade validation, and coordinated rollout so that security patches are applied consistently across the infrastructure. VCF Operations requires a precheck to succeed before scheduling component upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. However, updates are not applied automatically. An administrator must review available updates and initiate the update workflow.

For the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support a rolling update model for delivering security updates to cluster infrastructure. Updates are initiated by modifying the cluster specification, with VKS Controller updates encompassing supporting services such as the Container Networking Interface (CNI), Container Storage Interface (CSI), and Cloud Provider Interface (CPI) alongside configuration updates for the clusters themselves. This rolling update mechanism allows security patches to reach cluster infrastructure components in a controlled sequence without requiring full cluster downtime. At the workload level, Kubernetes Deployments support rolling updates that replace Pod instances incrementally, so security-patched container images can be deployed without interrupting running services. VCF Automation makes update and patch actions available to consumers through its self-service catalog, where day-2 actions including updates and patches can be initiated by the workload owner independently. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS releases, providing hardening guidance and defining baseline security configurations that inform operators of recommended configuration states.

The vCenter Patching API provides programmatic access to list available updates, run pre-check validations, and stage downloads. vCenter categorizes available updates with type labels including SECURITY and BUG FIX AND SECURITY, which administrators can use when reviewing available updates to prioritize security-specific patches. PowerCLI provides a Test-Compliance command that scans hosts and clusters against downloaded patches to identify what needs remediation. These tools allow administrators to integrate patch status checks into their operational workflows.

VCF includes several notification and detection mechanisms for security updates. VCF Operations components receive security-related updates in the form of VMware Security Advisories (VMSAs), which are the primary notification mechanism for available security patches. Emergency updates are released for VCF Operations integrations in response to system

degradation issues or security bulletins. VCF Operations provides advance notice of urgent interoperability and security updates at 72-hour and 24-hour intervals before the update becomes available. VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack by cross-referencing the installed versions against published VMSAs, surfacing the exposure with a description, root cause insight, and actionable remediation steps.

For container workloads on VKS clusters, Harbor Registry, available as a Supervisor Service, provides vulnerability scanning of stored container images and content trust controls to restrict the use of unscanned or untrusted images. This gives operators visibility into images that carry known vulnerabilities, informing decisions about which images require patching or replacement. The Prometheus standard package, installable on VKS clusters, deploys Prometheus and Alertmanager in the `tanzu-system-monitoring` namespace. Alertmanager receives alerts from Prometheus via HTTP and routes them to external notification channels including email and webhooks, supporting organizational workflows for notifying teams of conditions related to cluster health or component version thresholds. The AlertmanagerConfig custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external systems. For GitOps-driven environments, the ArgoCD Supervisor Service supports a notification controller that can be enabled via the `notification.enabled` configuration setting, allowing operators to receive alerts when application sync states change or when cluster state drifts from the desired configuration defined in a repository.

VCF also includes configurable notification capabilities that administrators can use for operational awareness. VMware vCenter can send email notifications and SNMP traps when alarms are triggered, with configurable recipient addresses. VCF Operations supports outbound SNMP trap notifications to external management systems, with up to four configurable trap destinations. While these notification mechanisms are designed for operational alerting rather than update notification specifically, they form part of the broader monitoring infrastructure that administrators use to maintain awareness of environment status.

These capabilities cover VCF infrastructure components and the Kubernetes consumption layer rather than all technology assets in the environment. Patching guest workloads and applications running on VCF, and maintaining container images with current security patches, remain the responsibility of the workload owners. The organization is responsible for subscribing to VMware Security Advisories, monitoring for new patches, evaluating applicability, and scheduling update windows according to change management processes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports update delivery through a configurable Maintenance Policy and an integrated upgrade management interface. The Maintenance Policy, set from the vSphere Client by a vSphere Administrator, allows administrators to schedule automatic software updates for DSM appliances and define the duration window during which updates are applied. Administrators configure a future date and time for the policy, giving organizations control over when DSM platform components are updated while reducing the manual coordination required to keep the platform current. When automatic plug-in updates fail, DSM recommends manual software updates of appliances as a fallback path.

DSM provides update discovery through a "Check for Upgrade" function, accessible in the Version & Upgrade section of the DSM UI via the DSM System tab. This function queries for available updates and displays them in the Available Upgrades table. Update bundles can be uploaded from a remote server URL with credentials or from a local file, giving administrators flexibility in sourcing release packages. Updates follow a staged progression: after a release bundle is uploaded, it transitions to a Ready to Install state before being applied during the configured maintenance window. The Version & Upgrade management interface allows administrators to track plug-in versions, release dates, and activation states.

DSM extends automatic upgrade coverage to managed databases. Administrators and users can activate automatic database upgrades by specifying a maintenance window for each data service. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, providing a mechanism for applying security-relevant patches to database instances on a defined schedule.

DSM adds SQL Server as a supported managed database type. SQL Server instances in DSM follow the Cumulative Update (CU) branch, which contains the complete set of functional, performance, and security updates for the major version, keeping SQL Server databases provisioned through DSM current with security-relevant patches as part of the standard update track.

DSM supports webhook notifications that can route system alerts to external destinations such as email, Slack channels, or ServiceNow. While these notification capabilities address operational events rather than dedicated security update announcements, they provide notification infrastructure that organizations can incorporate into update communication workflows.

Applying DSM plug-in updates requires administrators to upload release bundles and configure Maintenance Policies before automatic updates can apply. DSM does not natively send proactive notifications about available security updates to all affected users; that communication step depends on organizational processes outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) 9.1 supports security update notification through its event alerting framework and delivers automatic updates for certificate material and live security threat intelligence content.

The Avi Controller includes a configurable event alerting framework supporting four notification destinations: the local UI (displayed as colored bell icons), email, syslog, and SNMP v2c and SNMPv3 traps. Notification profiles are configured in the Operations > Notifications page. Alert configurations trigger on system events and route to one or more destinations, and can carry security-relevant notifications including conditions that signal a need for patching. SNMP notification transport can be configured with TLS encryption and strict certificate verification enabled.

For certificate-based security material, the Controller applies automatic updates. When a certificate held by the Avi Controller is updated through manual replacement, Let's Encrypt integration, or Venafi Trust Protection Platform integration, the updated certificate is automatically and transparently pushed to all Service Engines using that certificate. This propagation occurs without service interruption and without requiring separate operator action on each Service Engine. The Venafi Onboard Discovery feature automates importing certificates into Trust Protection Platform, where they can be monitored, validated, and provisioned, and Trust Protection Platform automatically handles certificate and chain certificate renewals based on the mapping of virtual service names to certificates.

Avi also introduces Live Security Threat Intelligence through the Avi Cloud Console, which provides automatic synchronization of security content to enabled deployments. The Application Rules service provides automatic synchronization of the Application Rules Database, delivering current application vulnerability protection rules without manual action. The Bot Management service includes a User Agent Database Sync capability that receives current User-Agent updates for threat detection. The IP Reputation service maintains a real-time, up-to-date security posture across globally distributed Avi Controller clusters by delivering current threat feed data automatically.

Avi WAF Enterprise license customers receive OWASP Core Rule Set (CRS) updates through the customer portal. These updates are available for download and are applied by administrators.

Software upgrade and patch operations for the Controller and Service Engine groups are administrator-initiated. During the term of a purchased subscription, customers have access to new software releases including software patches published by Broadcom for Avi Load Balancer and 24/7 support. The /api/upgrade REST API endpoint supports applying a base image, a Controller patch, and a Service Engine patch in a single operation. Upgrade, patch upgrade, rollback, and rollback patch operations are all supported. Virtual service disruption must be assessed and communicated before upgrade operations. In VCF deployments, Avi Management Plane alarms, alerts, and dashboards must be verified as operational as part of post-upgrade validation.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (3)

> apply effective and regular tests and reviews of the security of the product with digital elements;

SCF Controls: TDA-02.10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (4)

> once a security update has been made available, share and publicly disclose information about fixed vulnerabilities, including a description of the vulnerabilities, information allowing users to identify the product with digital elements affected, the impacts of the vulnerabilities, their severity and clear and accessible information helping users to remediate the vulnerabilities; in duly justified cases, where manufacturers consider the security risks of publication to outweigh the security benefits, they may delay making public information regarding a fixed vulnerability until after users have been given the possibility to apply the relevant patch;

SCF Controls: TDA-02.11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (5)

> put in place and enforce a policy on coordinated vulnerability disclosure;

SCF Controls: THR-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (6)

> take measures to facilitate the sharing of information about potential vulnerabilities in their product with digital elements as well as in third-party components contained in that product, including by providing a contact address for the reporting of the vulnerabilities discovered in the product with digital elements;

SCF Controls: TDA-02.11, TDA-04.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (7)

> provide for mechanisms to securely distribute updates for products with digital elements to ensure that vulnerabilities are fixed or mitigated in a timely manner and, where applicable for security updates, in an automatic manner;

SCF Controls: TDA-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides structured update delivery mechanisms and notification capabilities that support ongoing product security for its infrastructure components, though full automatic update delivery and proactive notification to all affected users require additional organizational processes.

VCF uses a tiered release model for delivering security fixes. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations and can be applied selectively to individual components without requiring synchronized updates across the entire VCF stack. These patch releases are issued between major, minor, and maintenance releases to address urgent security concerns. Maintenance releases are scheduled, cumulative updates that include bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. For VMware ESX hosts specifically, software updates including patches of the ESX base image, partner add-ons, IOVP drivers, and VMware Tools updates are available through online depots. For deployments without direct internet access, the vSphere Lifecycle Manager's Update Manager Download Service (UMDS) can be configured to download patch binaries, patch metadata, and host notifications to a local repository and serve them as an offline update source.

VCF Operations provides lifecycle management capabilities that orchestrate the update process across VCF components, including ESX hosts, vCenter, and NSX. The lifecycle management workflow handles dependency ordering, pre-upgrade validation, and coordinated rollout so that security patches are applied consistently across the infrastructure. VCF Operations requires a precheck to succeed before scheduling component upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. However, updates are not applied automatically. An administrator must review available updates and initiate the update workflow.

For the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support a rolling update model for delivering security updates to cluster infrastructure. Updates are initiated by modifying the cluster specification, with VKS Controller updates encompassing supporting services such as the Container Networking Interface (CNI), Container Storage Interface (CSI), and Cloud Provider Interface (CPI) alongside configuration updates for the clusters themselves. This rolling update mechanism allows security patches to reach cluster infrastructure components in a controlled sequence without requiring full cluster downtime. At the workload level, Kubernetes Deployments support rolling updates that replace Pod instances incrementally, so security-patched container images can be deployed without interrupting running services. VCF Automation makes update and patch actions available to consumers through its self-service catalog, where day-2 actions including updates and patches can be initiated by the workload owner independently. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS releases, providing hardening guidance and defining baseline security configurations that inform operators of recommended configuration states.

The vCenter Patching API provides programmatic access to list available updates, run pre-check validations, and stage downloads. vCenter categorizes available updates with type labels including SECURITY and BUG FIX AND SECURITY, which administrators can use when reviewing available updates to prioritize security-specific patches. PowerCLI provides a Test-Compliance command that scans hosts and clusters against downloaded patches to identify what needs remediation. These tools allow administrators to integrate patch status checks into their operational workflows.

VCF includes several notification and detection mechanisms for security updates. VCF Operations components receive security-related updates in the form of VMware Security Advisories (VMSAs), which are the primary notification mechanism for available security patches. Emergency updates are released for VCF Operations integrations in response to system degradation issues or security bulletins. VCF Operations provides advance notice of urgent interoperability and security

updates at 72-hour and 24-hour intervals before the update becomes available. VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack by cross-referencing the installed versions against published VMSAs, surfacing the exposure with a description, root cause insight, and actionable remediation steps.

For container workloads on VKS clusters, Harbor Registry, available as a Supervisor Service, provides vulnerability scanning of stored container images and content trust controls to restrict the use of unscanned or untrusted images. This gives operators visibility into images that carry known vulnerabilities, informing decisions about which images require patching or replacement. The Prometheus standard package, installable on VKS clusters, deploys Prometheus and Alertmanager in the `tanzu-system-monitoring` namespace. Alertmanager receives alerts from Prometheus via HTTP and routes them to external notification channels including email and webhooks, supporting organizational workflows for notifying teams of conditions related to cluster health or component version thresholds. The AlertmanagerConfig custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external systems. For GitOps-driven environments, the ArgoCD Supervisor Service supports a notification controller that can be enabled via the `notification.enabled` configuration setting, allowing operators to receive alerts when application sync states change or when cluster state drifts from the desired configuration defined in a repository.

VCF also includes configurable notification capabilities that administrators can use for operational awareness. VMware vCenter can send email notifications and SNMP traps when alarms are triggered, with configurable recipient addresses. VCF Operations supports outbound SNMP trap notifications to external management systems, with up to four configurable trap destinations. While these notification mechanisms are designed for operational alerting rather than update notification specifically, they form part of the broader monitoring infrastructure that administrators use to maintain awareness of environment status.

These capabilities cover VCF infrastructure components and the Kubernetes consumption layer rather than all technology assets in the environment. Patching guest workloads and applications running on VCF, and maintaining container images with current security patches, remain the responsibility of the workload owners. The organization is responsible for subscribing to VMware Security Advisories, monitoring for new patches, evaluating applicability, and scheduling update windows according to change management processes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports update delivery through a configurable Maintenance Policy and an integrated upgrade management interface. The Maintenance Policy, set from the vSphere Client by a vSphere Administrator, allows administrators to schedule automatic software updates for DSM appliances and define the duration window during which updates are applied. Administrators configure a future date and time for the policy, giving organizations control over when DSM platform components are updated while reducing the manual coordination required to keep the platform current. When automatic plug-in updates fail, DSM recommends manual software updates of appliances as a fallback path.

DSM provides update discovery through a "Check for Upgrade" function, accessible in the Version & Upgrade section of the DSM UI via the DSM System tab. This function queries for available updates and displays them in the Available Upgrades table. Update bundles can be uploaded from a remote server URL with credentials or from a local file, giving administrators flexibility in sourcing release packages. Updates follow a staged progression: after a release bundle is uploaded, it transitions to a Ready to Install state before being applied during the configured maintenance window. The Version & Upgrade management interface allows administrators to track plug-in versions, release dates, and activation states.

DSM extends automatic upgrade coverage to managed databases. Administrators and users can activate automatic database upgrades by specifying a maintenance window for each data service. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, providing a mechanism for applying security-relevant patches to database instances on a defined schedule.

DSM adds SQL Server as a supported managed database type. SQL Server instances in DSM follow the Cumulative Update (CU) branch, which contains the complete set of functional, performance, and security updates for the major version, keeping SQL Server databases provisioned through DSM current with security-relevant patches as part of the standard update track.

DSM supports webhook notifications that can route system alerts to external destinations such as email, Slack channels, or ServiceNow. While these notification capabilities address operational events rather than dedicated security update announcements, they provide notification infrastructure that organizations can incorporate into update communication workflows.

Applying DSM plug-in updates requires administrators to upload release bundles and configure Maintenance Policies before automatic updates can apply. DSM does not natively send proactive notifications about available security updates to all affected users; that communication step depends on organizational processes outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) 9.1 supports security update notification through its event alerting framework and delivers automatic updates for certificate material and live security threat intelligence content.

The Avi Controller includes a configurable event alerting framework supporting four notification destinations: the local UI (displayed as colored bell icons), email, syslog, and SNMP v2c and SNMPv3 traps. Notification profiles are configured in the Operations > Notifications page. Alert configurations trigger on system events and route to one or more destinations, and can carry security-relevant notifications including conditions that signal a need for patching. SNMP notification transport can be configured with TLS encryption and strict certificate verification enabled.

For certificate-based security material, the Controller applies automatic updates. When a certificate held by the Avi Controller is updated through manual replacement, Let's Encrypt integration, or Venafi Trust Protection Platform integration, the updated certificate is automatically and transparently pushed to all Service Engines using that certificate. This propagation occurs without service interruption and without requiring separate operator action on each Service Engine. The Venafi Onboard Discovery feature automates importing certificates into Trust Protection Platform, where they can be monitored, validated, and provisioned, and Trust Protection Platform automatically handles certificate and chain certificate renewals based on the mapping of virtual service names to certificates.

Avi also introduces Live Security Threat Intelligence through the Avi Cloud Console, which provides automatic synchronization of security content to enabled deployments. The Application Rules service provides automatic synchronization of the Application Rules Database, delivering current application vulnerability protection rules without manual action. The Bot Management service includes a User Agent Database Sync capability that receives current User-Agent updates for threat detection. The IP Reputation service maintains a real-time, up-to-date security posture across globally distributed Avi Controller clusters by delivering current threat feed data automatically.

Avi WAF Enterprise license customers receive OWASP Core Rule Set (CRS) updates through the customer portal. These updates are available for download and are applied by administrators.

Software upgrade and patch operations for the Controller and Service Engine groups are administrator-initiated. During the term of a purchased subscription, customers have access to new software releases including software patches published by Broadcom for Avi Load Balancer and 24/7 support. The /api/upgrade REST API endpoint supports applying a base image, a Controller patch, and a Service Engine patch in a single operation. Upgrade, patch upgrade, rollback, and rollback patch operations are all supported. Virtual service disruption must be assessed and communicated before upgrade operations. In VCF deployments, Avi Management Plane alarms, alerts, and dashboards must be verified as operational as part of post-upgrade validation.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex I Part II (8)

> ensure that, where security updates are available to address identified security issues, they are disseminated without delay and, unless otherwise agreed between a manufacturer and a business user in relation to a tailor-made product with digital elements, free of charge, accompanied by advisory messages providing users with the relevant information, including on potential action to be taken.

SCF Controls: TDA-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides structured update delivery mechanisms and notification capabilities that support ongoing product security for its infrastructure components, though full automatic update delivery and proactive notification to all affected users require additional organizational processes.

VCF uses a tiered release model for delivering security fixes. Patch releases provide time-sensitive fixes to security and catastrophic issues impacting business operations and can be applied selectively to individual components without requiring synchronized updates across the entire VCF stack. These patch releases are issued between major, minor, and maintenance releases to address urgent security concerns. Maintenance releases are scheduled, cumulative updates that include bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact. For VMware ESX hosts specifically, software updates including patches of the ESX base image, partner add-ons, IOVP drivers, and VMware Tools updates are available through online depots. For deployments without direct internet access, the vSphere Lifecycle Manager's Update Manager Download Service (UMDS) can be configured to download patch binaries, patch metadata, and host notifications to a local repository and serve them as an offline update source.

VCF Operations provides lifecycle management capabilities that orchestrate the update process across VCF components, including ESX hosts, vCenter, and NSX. The lifecycle management workflow handles dependency ordering, pre-upgrade validation, and coordinated rollout so that security patches are applied consistently across the infrastructure. VCF Operations requires a precheck to succeed before scheduling component upgrades, and requires acknowledgment of any errors or warnings in the precheck report before proceeding. However, updates are not applied automatically. An administrator must review available updates and initiate the update workflow.

For the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters support a rolling update model for delivering security updates to cluster infrastructure. Updates are initiated by modifying the cluster specification, with VKS Controller updates encompassing supporting services such as the Container Networking Interface (CNI), Container Storage Interface (CSI), and Cloud Provider Interface (CPI) alongside configuration updates for the clusters themselves. This rolling update mechanism allows security patches to reach cluster infrastructure components in a controlled sequence without requiring full cluster downtime. At the workload level, Kubernetes Deployments support rolling updates that replace Pod instances incrementally, so security-patched container images can be deployed without interrupting running services. VCF Automation makes update and patch actions available to consumers through its self-service catalog, where day-2 actions including updates and patches can be initiated by the workload owner independently. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS releases, providing hardening guidance and defining baseline security configurations that inform operators of recommended configuration states.

The vCenter Patching API provides programmatic access to list available updates, run pre-check validations, and stage downloads. vCenter categorizes available updates with type labels including SECURITY and BUG FIX AND SECURITY, which administrators can use when reviewing available updates to prioritize security-specific patches. PowerCLI provides a Test-Compliance command that scans hosts and clusters against downloaded patches to identify what needs remediation. These tools allow administrators to integrate patch status checks into their operational workflows.

VCF includes several notification and detection mechanisms for security updates. VCF Operations components receive security-related updates in the form of VMware Security Advisories (VMSAs), which are the primary notification mechanism for

available security patches. Emergency updates are released for VCF Operations integrations in response to system degradation issues or security bulletins. VCF Operations provides advance notice of urgent interoperability and security updates at 72-hour and 24-hour intervals before the update becomes available. VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack by cross-referencing the installed versions against published VMSAs, surfacing the exposure with a description, root cause insight, and actionable remediation steps.

For container workloads on VKS clusters, Harbor Registry, available as a Supervisor Service, provides vulnerability scanning of stored container images and content trust controls to restrict the use of unscanned or untrusted images. This gives operators visibility into images that carry known vulnerabilities, informing decisions about which images require patching or replacement. The Prometheus standard package, installable on VKS clusters, deploys Prometheus and Alertmanager in the `tanzu-system-monitoring` namespace. Alertmanager receives alerts from Prometheus via HTTP and routes them to external notification channels including email and webhooks, supporting organizational workflows for notifying teams of conditions related to cluster health or component version thresholds. The AlertmanagerConfig custom resource definition specifies how alerts are grouped, inhibited, and forwarded to external systems. For GitOps-driven environments, the ArgoCD Supervisor Service supports a notification controller that can be enabled via the `notification.enabled` configuration setting, allowing operators to receive alerts when application sync states change or when cluster state drifts from the desired configuration defined in a repository.

VCF also includes configurable notification capabilities that administrators can use for operational awareness. VMware vCenter can send email notifications and SNMP traps when alarms are triggered, with configurable recipient addresses. VCF Operations supports outbound SNMP trap notifications to external management systems, with up to four configurable trap destinations. While these notification mechanisms are designed for operational alerting rather than update notification specifically, they form part of the broader monitoring infrastructure that administrators use to maintain awareness of environment status.

These capabilities cover VCF infrastructure components and the Kubernetes consumption layer rather than all technology assets in the environment. Patching guest workloads and applications running on VCF, and maintaining container images with current security patches, remain the responsibility of the workload owners. The organization is responsible for subscribing to VMware Security Advisories, monitoring for new patches, evaluating applicability, and scheduling update windows according to change management processes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports update delivery through a configurable Maintenance Policy and an integrated upgrade management interface. The Maintenance Policy, set from the vSphere Client by a vSphere Administrator, allows administrators to schedule automatic software updates for DSM appliances and define the duration window during which updates are applied. Administrators configure a future date and time for the policy, giving organizations control over when DSM platform components are updated while reducing the manual coordination required to keep the platform current. When automatic plug-in updates fail, DSM recommends manual software updates of appliances as a fallback path.

DSM provides update discovery through a "Check for Upgrade" function, accessible in the Version & Upgrade section of the DSM UI via the DSM System tab. This function queries for available updates and displays them in the Available Upgrades table. Update bundles can be uploaded from a remote server URL with credentials or from a local file, giving administrators flexibility in sourcing release packages. Updates follow a staged progression: after a release bundle is uploaded, it transitions to a Ready to Install state before being applied during the configured maintenance window. The Version & Upgrade management interface allows administrators to track plug-in versions, release dates, and activation states.

DSM extends automatic upgrade coverage to managed databases. Administrators and users can activate automatic database upgrades by specifying a maintenance window for each data service. Upgrade operations performed during the maintenance window may include CVE fixes, bug fixes, and performance improvements, providing a mechanism for applying security-relevant patches to database instances on a defined schedule.

DSM adds SQL Server as a supported managed database type. SQL Server instances in DSM follow the Cumulative Update (CU) branch, which contains the complete set of functional, performance, and security updates for the major version, keeping SQL Server databases provisioned through DSM current with security-relevant patches as part of the standard update track.

DSM supports webhook notifications that can route system alerts to external destinations such as email, Slack channels, or ServiceNow. While these notification capabilities address operational events rather than dedicated security update announcements, they provide notification infrastructure that organizations can incorporate into update communication workflows.

Applying DSM plug-in updates requires administrators to upload release bundles and configure Maintenance Policies before automatic updates can apply. DSM does not natively send proactive notifications about available security updates to all affected users; that communication step depends on organizational processes outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) 9.1 supports security update notification through its event alerting framework and delivers automatic updates for certificate material and live security threat intelligence content.

The Avi Controller includes a configurable event alerting framework supporting four notification destinations: the local UI (displayed as colored bell icons), email, syslog, and SNMP v2c and SNMPv3 traps. Notification profiles are configured in the Operations > Notifications page. Alert configurations trigger on system events and route to one or more destinations, and can carry security-relevant notifications including conditions that signal a need for patching. SNMP notification transport can be configured with TLS encryption and strict certificate verification enabled.

For certificate-based security material, the Controller applies automatic updates. When a certificate held by the Avi Controller is updated through manual replacement, Let's Encrypt integration, or Venafi Trust Protection Platform integration, the updated certificate is automatically and transparently pushed to all Service Engines using that certificate. This propagation occurs without service interruption and without requiring separate operator action on each Service Engine. The Venafi Onboard Discovery feature automates importing certificates into Trust Protection Platform, where they can be monitored, validated, and provisioned, and Trust Protection Platform automatically handles certificate and chain certificate renewals based on the mapping of virtual service names to certificates.

Avi also introduces Live Security Threat Intelligence through the Avi Cloud Console, which provides automatic synchronization of security content to enabled deployments. The Application Rules service provides automatic synchronization of the Application Rules Database, delivering current application vulnerability protection rules without manual action. The Bot Management service includes a User Agent Database Sync capability that receives current User-Agent updates for threat detection. The IP Reputation service maintains a real-time, up-to-date security posture across globally distributed Avi Controller clusters by delivering current threat feed data automatically.

Avi WAF Enterprise license customers receive OWASP Core Rule Set (CRS) updates through the customer portal. These updates are available for download and are applied by administrators.

Software upgrade and patch operations for the Controller and Service Engine groups are administrator-initiated. During the term of a purchased subscription, customers have access to new software releases including software patches published by Broadcom for Avi Load Balancer and 24/7 support. The /api/upgrade REST API endpoint supports applying a base image, a Controller patch, and a Service Engine patch in a single operation. Upgrade, patch upgrade, rollback, and rollback patch operations are all supported. Virtual service disruption must be assessed and communicated before upgrade operations. In VCF deployments, Avi Management Plane alarms, alerts, and dashboards must be verified as operational as part of post-upgrade validation.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (1)

> the name, registered trade name or registered trademark of the manufacturer, and the postal address, the email address or other digital contact as well as, where available, the website at which the manufacturer can be contacted;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (2)

> the single point of contact where information about vulnerabilities of the product with digital elements can be reported and received, and where the manufacturer's policy on coordinated vulnerability disclosure can be found;

SCF Controls: TDA-01.1, THR-06.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (3)

> name and type and any additional information enabling the unique identification of the product with digital elements;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (4)

> the intended purpose of the product with digital elements, including the security environment provided by the manufacturer, as well as the product's essential functionalities and information about the security properties;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (5)

> any known or foreseeable circumstance, related to the use of the product with digital elements in accordance with its intended purpose or under conditions of reasonably foreseeable misuse, which may lead to significant cybersecurity risks;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (6)

> where applicable, the internet address at which the EU declaration of conformity can be accessed;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (7)

> the type of technical security support offered by the manufacturer and the end-date of the support period during which users can expect vulnerabilities to be handled and to receive security updates;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (8)

> detailed instructions or an internet address referring to such detailed instructions and information on:

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (8)(a)

> the necessary measures during initial commissioning and throughout the lifetime of the product with digital elements to ensure its secure use;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (8)(b)

> how changes to the product with digital elements can affect the security of data;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (8)(c)

> how security-relevant updates can be installed;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (8)(d)

> the secure decommissioning of the product with digital elements, including information on how user data can be securely removed;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex II (9)

> If the manufacturer decides to make available the software bill of materials to the user, information on where the software bill of materials can be accessed.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (1)

> Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (2)

> Standalone and embedded browsers

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (3)

> Password managers

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (4)

> Software that searches for, removes, or quarantines malicious software

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (5)

> Products with digital elements with the function of virtual private network (VPN)

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (6)

> Network management systems

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (7)

> Security information and event management (SIEM) systems

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (8)

> Boot managers

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (9)

> Public key infrastructure and digital certificate issuance software

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (10)

> Physical and virtual network interfaces

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (11)

> Operating systems

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (12)

> Routers, modems intended for the connection to the internet, and switches

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (13)

> Microprocessors with security-related functionalities

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (14)

> Microcontrollers with security-related functionalities

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class I (15)

> Application specific integrated circuits (ASIC) and field-programmable gate arrays (FPGA) with security-related functionalities

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class II (1)

> Hypervisors and container runtime systems that support virtualised execution of operating systems and similar environments

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class II (2)

> Firewalls, intrusion detection and prevention systems

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex III Class II (3)

> Tamper-resistant microprocessors

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex IV (1)

> Hardware Devices with Security Boxes

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex IV (2)

> Smart meter gateways within smart metering systems as defined in Article 2, point (23) of Directive (EU) 2019/944 of the European Parliament and of the Council (1) and other devices for advanced security purposes, including for secure cryptoprocessing

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex IV (3)

> Smartcards or similar devices, including secure elements

SCF Controls: TDA-02.12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V

> EU DECLARATION OF CONFORMITY The EU declaration of conformity referred to in Article 28, shall contain all of the following information:

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (1)

> Name and type and any additional information enabling the unique identification of the product with digital elements

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (2)

> Name and address of the manufacturer or its authorised representative

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (3)

> A statement that the EU declaration of conformity is issued under the sole responsibility of the provider

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (4)

> Object of the declaration (identification of the product with digital elements allowing traceability, which may include a photograph, where appropriate)

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (5)

> A statement that the object of the declaration described above is in conformity with the relevant Union harmonisation legislation

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (6)

> References to any relevant harmonised standards used or any other common specification or cybersecurity certification in relation to which conformity is declared

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (7)

> Where applicable, the name and number of the notified body, a description of the conformity assessment procedure performed and identification of the certificate issued

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex V (8)

> Additional information: Signed for and on behalf of: (place and date of issue): (name, function) (signature):

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII

> CONTENT OF THE TECHNICAL DOCUMENTATION The technical documentation referred to in Article 31 shall contain at least the following information, as applicable to the relevant product with digital elements:

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (1)

> a general description of the product with digital elements, including:

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (1)(a)

> its intended purpose;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (1)(b)

> versions of software affecting compliance with essential cybersecurity requirements;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (1)(c)

> where the product with digital elements is a hardware product, photographs or illustrations showing external features, marking and internal layout;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (1)(d)

> user information and instructions as set out in Annex II;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (2)

> a description of the design, development and production of the product with digital elements and vulnerability handling processes, including:

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (2)(a)

> necessary information on the design and development of the product with digital elements, including, where applicable, drawings and schemes and a description of the system architecture explaining how software components build on or feed into each other and integrate into the overall processing;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (2)(b)

> necessary information and specifications of the vulnerability handling processes put in place by the manufacturer, including the software bill of materials, the coordinated vulnerability disclosure policy, evidence of the provision of a contact address for the reporting of the vulnerabilities and a description of the technical solutions chosen for the secure distribution of updates;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (2)(c)

> necessary information and specifications of the production and monitoring processes of the product with digital elements and the validation of those processes;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (3)

> an assessment of the cybersecurity risks against which the product with digital elements is designed, developed, produced, delivered and maintained pursuant to Article 13, including how the essential cybersecurity requirements set out in Part I of Annex I are applicable;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (5)

> a list of the harmonised standards applied in full or in part the references of which have been published in the Official Journal of the European Union , common specifications as set out in Article 27 of this Regulation or European cybersecurity certification schemes adopted pursuant to Regulation (EU) 2019/881 pursuant to Article 27(8) of this Regulation, and, where those harmonised standards, common specifications or European cybersecurity certification schemes have not been applied, descriptions of the solutions adopted to meet the essential cybersecurity requirements set out in Parts I and II of Annex I, including a list of other relevant technical specifications applied. In the event of partly applied harmonised standards, common specifications or European cybersecurity certification schemes, the technical documentation shall specify the parts which have been applied;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (6)

> reports of the tests carried out to verify the conformity of the product with digital elements and of the vulnerability handling processes with the applicable essential cybersecurity requirements as set out in Parts I and II of Annex I;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (7)

> a copy of the EU declaration of conformity;

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VII (8)

> where applicable, the software bill of materials, further to a reasoned request from a market surveillance authority provided that it is necessary in order for that authority to be able to check compliance with the essential cybersecurity requirements set out in Annex I.

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part I (1)

> Internal control is the conformity assessment procedure whereby the manufacturer fulfils the obligations set out in points 2, 3 and 4 of this Part, and ensures and declares on its sole responsibility that the products with digital elements satisfy all the essential cybersecurity requirements set out in Part I of Annex I and the manufacturer meets the essential cybersecurity requirements set out in Part II of Annex I.

SCF Controls: CPL-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The BadgeCompliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual

obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part I (2)

> The manufacturer shall draw up the technical documentation described in Annex VII.

SCF Controls: TDA-22

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part I (3)

> Design, development, production and vulnerability handling of products with digital elements The manufacturer shall take all measures necessary so that the design, development, production and vulnerability handling processes and their monitoring ensure compliance of the manufactured or developed products with digital elements and of the processes put in place by the manufacturer with the essential cybersecurity requirements set out in Parts I and II of Annex I.

SCF Controls: TDA-01.1, TDA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part I (5)

> Authorised representatives The manufacturer's obligations set out in point 4 may be fulfilled by its authorised representative, on its behalf and under its responsibility, provided that the relevant obligations are specified in the mandate.

SCF Controls: CPL-08, CPL-08.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part II (4.1)

> examine the technical documentation and supporting evidence to assess the adequacy of the technical design and development of the product with digital elements with the essential cybersecurity requirements set out in Part I of Annex I and of the vulnerability handling processes put in place by the manufacturer with the essential cybersecurity requirements set out in Part II of Annex I;

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part II (10)

> The manufacturer shall keep a copy of the EU-type examination certificate, its annexes and additions together with the technical documentation at the disposal of the national authorities for 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer.

SCF Controls: DCH-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable data retention controls within VCF Operations that allow administrators to align operational data retention periods with organizational requirements. These controls do not address the full scope of media and data retention governance, but they give administrators granular tuning over how long different categories of platform-generated data are kept.

VCF Operations exposes data retention settings through Administration > Global Settings > Data Retention. Administrators can configure retention periods independently for several data categories. Metrics data supports a retention window between 1 month and 13 months. Entities and configuration data can be retained for a minimum of 1 month and a maximum of 3 months. Organization reports support a maximum data retention period of 1,440 days. At the normal retention tier, VCF Operations retains data at 5-minute granularity for 6 months, then rolls up the seventh month into 1-hour aggregations. A real-time retention tier provides 5-minute granularity, a standard tier retains data for 1 month, and a long-term tier retains data for 13 months. Different data retention policies can be configured and controlled for each category according to organizational requirements. Log data is governed separately through VCF Log Management, where administrators define log partitions that each carry their own retention period in days, with logs removed from disk automatically once a partition's period elapses and the option to archive partitions to external NFS or S3 storage for longer-term preservation.

VCF Operations for Networks provides additional granular retention controls. The default data retention period is 1 month in the advanced license edition. Flow data retention is fixed at a 1-month window within the platform. For organizations that need to retain flow data beyond one month, the Streaming Databus provides a mechanism to export flows to an external subscriber via HTTPS/HTTP for extended retention. Miscellaneous data retention can be configured with up to 100 GB of additional disk space.

VCF Operations also provides backup capabilities that support regulatory and operational retention needs. Administrators can take regular backups of both custom and out-of-the-box content. When reducing an entity metrics retention period in VCF Operations for Networks, the recommendation is to back up log files first to prevent data loss, which supports the principle of preserving data before modifying retention windows.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds Kubernetes-native persistent storage lifecycle controls relevant to data retention for containerized workloads. Persistent volumes in Supervisor namespaces store application data outside the lifecycle of individual pods and workloads, so data remains available when workloads restart or scale. The central mechanism governing retention behavior is the PersistentVolume reclaim policy, which controls what happens to the underlying storage and its data when the associated PersistentVolumeClaim is deleted. The Retain policy preserves the volume and its data in a Released state for manual administrator reclamation, leaving the data intact for inspection, archival, or transfer before final disposal. The Delete policy causes the storage asset to be removed when the claim is released. Retain is the default for manually provisioned PersistentVolumes. StorageClass definitions carry a ReclaimPolicy field that sets the default behavior for all dynamically provisioned volumes within a given storage class, allowing cluster administrators to enforce organization-wide retention defaults at the storage class level rather than per-volume. For StatefulSet workloads, Kubernetes provides a persistentVolumeClaimRetentionPolicy setting with a whenDeleted field that controls whether PVCs and their backing volumes are retained or deleted when the StatefulSet is removed; scaling a StatefulSet down does not delete the associated volumes by default. Organizations subject to retention obligations should configure StorageClasses with the Retain policy so that workload termination does not destroy data that must be kept for a defined period.

Storage Policy Based Management (SPBM) provides a unified control plane across VKS storage, enabling storage policies to be associated with persistent volumes that capture the storage characteristics required by a given workload or retention regime. VKS clusters surface a storage compliance status per volume: a Compliant status indicates that the datastore backing the volume satisfies the requirements of the associated policy; an Out of Date status indicates the policy has been updated but the new requirements have not yet been communicated to the datastore, requiring the policy to be reapplied to bring the volume back into compliance. This policy-driven model allows administrators to codify storage requirements and verify adherence continuously.

For Harbor Registry deployments on VKS clusters, administrators should note that configuring a StorageClass or PersistentVolume with a Delete reclaim policy results in all Harbor data being deleted when the Harbor package is removed. Image artifact retention requirements should drive reclaim policy selection for Harbor-backing storage. Platform teams should also manage data protection storage locations in VCF Automation to align with company-specific data residency and infrastructure standards.

These retention controls apply to the operational, monitoring, and configuration data that VCF Operations collects and manages, and to the persistent volume lifecycle for containerized workloads on VKS. They do not extend to application data stored within virtual machines outside the Kubernetes layer, user-generated content on datastores not managed by Kubernetes, or media outside the VCF platform. Organizations must establish broader data retention policies, classification schemes, and lifecycle management processes that address all media and data types subject to statutory, regulatory, and contractual obligations. VCF's retention settings are one component of a larger retention program that requires organizational governance, legal review of applicable obligations, and potentially additional tools for archival and disposition of data beyond what VCF Operations and VKS storage lifecycle controls manage.

VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control Annex VIII Part III (2)

> Production The manufacturer shall take all measures necessary so that the production and its monitoring ensure conformity of the manufactured products with digital elements with the approved type described in the EU-type examination certificate and with the essential cybersecurity requirements as set out in Part I of Annex I and ensures that the manufacturer meets the essential cybersecurity requirements set out in Part II of Annex I.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part III (3)

> Conformity marking and declaration of conformity

SCF Controls: CPL-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part III (3.1)

> The manufacturer shall affix the CE marking to each individual product with digital elements that is in conformity with the type described in the EU-type examination certificate and satisfies the applicable requirements set out in this Regulation.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part III (3.2)

> The manufacturer shall draw up a written declaration of conformity for a product model and keep it at the disposal of the national authorities for 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer. The declaration of conformity shall identify the product model for which it has been drawn up. A copy of the declaration of conformity shall be made available to the relevant authorities upon request.

SCF Controls: CPL-01.5, DCH-18

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part III (4)

> Authorised representative The manufacturer's obligations set out in point 3 may be fulfilled by its authorised representative, on its behalf and under its responsibility, provided that the relevant obligations are specified in the mandate.

SCF Controls: CPL-08, CPL-08.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part IV (2)

> Design, development, production and vulnerability handling of products with digital elements The manufacturer shall operate an approved quality system as specified in point 3 for the design, development and final product inspection and testing of the products with digital elements concerned and for handling vulnerabilities, maintain its effectiveness throughout the support period, and shall be subject to surveillance as specified in point 4.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part IV (3.1)

> The manufacturer shall lodge an application for assessment of its quality system with the notified body of its choice, for the products with digital elements concerned. The application shall include:

SCF Controls: CPL-03.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part IV (3.4)

> The manufacturer shall undertake to fulfil the obligations arising out of the quality system as approved and to maintain it so that it remains adequate and efficient.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part IV (3.5)

> The manufacturer shall keep the notified body that has approved the quality system informed of any intended change to the quality system. The notified body shall evaluate any proposed changes and decide whether the modified quality system will continue to satisfy the requirements referred to in point 3.2 or whether a reassessment is necessary. It shall notify the manufacturer of its decision. The notification shall contain the conclusions of the examination and the reasoned assessment decision.

SCF Controls: CPL-03.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part IV (4.2)

> The manufacturer shall, for assessment purposes, allow the notified body access to the design, development, production, inspection, testing and storage sites, and shall provide it with all necessary information, in particular:

SCF Controls: CPL-03.3

Aggregate Coverage: Contributes

VCF (Contributes)

The control requires granting assessors minimum necessary access to conduct conformity assessments, including logical access to design, development, production, inspection, and testing artifacts, as well as physical access to facilities. VCF provides granular role-based access control mechanisms across its components that allow organizations to create appropriately scoped accounts for assessors conducting compliance or security assessments.

VMware vCenter implements a privilege system where privileges are grouped into roles that can be mapped to users or groups. The platform includes a built-in Read Only role that grants three system-defined privileges (System.Anonymous, System.View, and System.Read), providing a baseline for assessor access that allows viewing configuration and operational data without the ability to modify the environment. Read privileges can be assigned at the datacenter or vCenter level, allowing organizations to scope assessor visibility to specific portions of the infrastructure. For more tailored access, vCenter supports custom role creation with granular privilege assignment and permission propagation to vSphere objects, enabling organizations to build assessor-specific roles that include only the privileges needed for a particular assessment engagement. The operator role in vCenter provides another restricted authorization level where users can view information about vCenter but cannot alter its configuration. VCF SSO also includes a SystemConfiguration.ReadOnly privilege that grants members read-only access to vCenter appliance operations under Appliance Management, providing a targeted option for assessors whose scope includes appliance configuration review. New users and groups are assigned the No Access role by default in vCenter, so assessor accounts start with no visibility and require explicit permission assignments before any infrastructure objects become accessible.

VCF Operations provides its own ReadOnly role that allows users to perform read operations but restricts write actions such as create, update, or delete. Permissions for specific functional areas, such as Infrastructure Operations and the Analyze page, are managed in the Roles tab under Administration > Control Panel, where individual permissions can be selected or deselected when adding or editing a role. This granularity allows organizations to tailor assessor access to the specific operational data relevant to the assessment scope.

VCF Automation includes several roles suited to assessor access. The Organization Auditor role provides read-only access equivalent to the Organization Administrator role, allowing auditors to view anything an administrator can see without the ability to edit or manage users and groups. The Project Auditor role is similarly restricted to read-only access at the project level. The Project Viewer role is restricted to read-only access, except in cases where viewers can perform non-destructive actions such as downloading cloud templates. Organizations can also create custom user roles in VCF Automation to expand or restrict permissions for specific project resources without granting broader administrative capability.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, provides a dedicated access control framework for granting assessors minimum-necessary access to Kubernetes workloads and related artifacts. At the vSphere Namespace level, administrators can assign VCF SSO users and groups to one of three permission levels: Can View, Can Edit, or Owner. The Can View role grants read-only access to VKS cluster objects provisioned in the namespace and maps no permissions to Kubernetes roles within those clusters, making it appropriate for assessors who need to review namespace-scoped workload configurations without the ability to modify cluster resources. VCF Consumption CLI access to vSphere Namespaces is enforced based on user permissions, and users without sufficient permissions cannot connect to the Supervisor or its VKS clusters. Within VKS clusters, Kubernetes RBAC provides the built-in view ClusterRole, which gives read-only access to most objects in a namespace but excludes visibility into roles and role bindings, allowing assessors to inspect workload and policy configurations without being able to examine or modify the cluster's access control structure. Administrators can also create custom Roles and RoleBindings scoped to specific namespaces, and Kubernetes ABAC rules support a readonly access mode to restrict users to read-only operations on

specified resources. Kubernetes RBAC enforces that a RoleBinding cannot grant permissions the grantor does not already hold, which prevents privilege escalation when provisioning assessor accounts. RoleBinding subjects in VKS clusters must reference VCF SSO user or group names, keeping assessor identity management integrated with the platform's central identity directory. Access to the VKS Policy Insights page, which provides centralized visibility into the governance health of the VKS cluster estate, is restricted to the Organization Auditor and related roles, allowing organizations to grant assessors read-only policy visibility without broader operational rights. Harbor Registry, available as a standard package on VKS clusters, enforces RBAC to control access to container image artifacts, allowing organizations to grant assessors read access to specific image repositories relevant to their assessment scope.

The platform's authorization model verifies what objects each principal has access to, and the recommendation across VCF components is to configure users with the specific privileges required for their role rather than assigning overly permissive roles. Organizations should define assessor-specific roles in each VCF component that grant read access only to the artifacts relevant to the assessment scope.

VCF supports identity federation through standard protocols, which allows assessor accounts to be provisioned through an organization's existing identity provider rather than creating local accounts. Identity provider federation uses token-based authentication and supports multifactor authentication. This simplifies lifecycle management and helps ensure assessor credentials are deprovisioned when the engagement ends.

VCF also provides audit logging capabilities that create a record of assessor actions during an engagement. VCF Operations user activity audit reports provide traceability of user activities including logging in, actions on clusters and nodes, changes to system passwords, activating certificates, and logging out. These audit logs can be downloaded in PDF or XLS format. VCF Automation audit logs capture action details including timestamps, user names, project names, and trace IDs. This auditability allows organizations to verify that assessors operated within the bounds of their granted access.

Physical access to facilities is outside VCF's scope as a software platform. Organizations must address physical facility access through their own site security and visitor management processes.

VMware vDefend (Contributes)

VMware vDefend contributes to granting assessors minimum necessary logical access through the role-based access control (RBAC) framework of its Security Services Platform. The framework defines three permission levels: Full Access, which encompasses create, read, update, and delete operations; Read, which provides read-only visibility; and No Access, which excludes all operations.

A dedicated Auditor role is available for personnel who need to review configurations without making changes. In VMware vDefend, the Auditor role holds Read permissions for platform operations including deploying, managing, and upgrading the Security Services Platform, configuring authentication and authorization, performing server configuration, managing backup and restore, and activating Security Intelligence. The Auditor role also has Full Access to view Rule Analysis results and download rule analysis reports, giving assessors the ability to examine how firewall policy rules align with observed traffic behavior. For other operations, including exporting data, publishing segmentation policies and group definitions, managing discovery and inventory assets, and configuring Security Intelligence data collection, the Auditor role holds Restricted permissions that limit its ability to alter state.

Five platform roles are defined with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Enterprise Admin and Security Engineer hold Full Access to export traffic flows, monitor infrastructure, environment, and application telemetry, configure Security Intelligence data collection, and visualize traffic flows. This role hierarchy allows administrators to assign the Auditor role to assessors while granting elevated operational permissions only to engineering and administrative staff.

Physical access to facilities is outside the scope of VMware vDefend and must be addressed through separate facility access management processes and organizational controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access control (RBAC) mechanisms that support granting assessors minimum necessary logical access to disaster recovery artifacts.

PNR restricts login to VMware vCenter administrators by default; other users require an explicit permission grant from an administrator to access PNR. Permissions are required on both vCenter objects and PNR-specific objects, giving administrators granular control over what each user can see and do within the platform. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, making the permission model consistent across sites in a two-site configuration.

For assessors who need access to recovery plan operations without full administrative rights, permissions for testing and running recovery plans can be assigned separately in PNR. In shared recovery site configurations, the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use protection and recovery for their own protected site without access to resources belonging to other organizations. Site-wide permission assignments must be added on a per-site basis, with corresponding permissions required on both the protected and recovery sites. Users or user groups assigned a PNR role that are not vCenter administrators do not obtain vSphere Replication privileges; assessors who require access to both PNR operations and vSphere Replication should be placed in separate user groups for each role type, avoiding the need to grant full vCenter administrator privileges.

When PNR is deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, providing additional scoping options for multi-tenant environments.

PNR also includes a Clean Room Orchestrator where access is restricted to IP addresses and IP address ranges configured in a management access list, limiting which hosts can reach the clean room environment used for ransomware recovery and analysis.

Physical access to facilities is outside the scope of PNR and remains an organizational responsibility.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides role-based access control in the Avi Controller that administrators can use to create role-scoped accounts for assessors, granting minimum necessary access to the application delivery environment. Avi roles define two distinct access types: Write privilege allows users to create, read, modify, and delete resources, while Read privilege restricts users to reading existing configuration, viewing health and analytics data, and viewing audit logs without modification capability. This allows assessor accounts to be provisioned with observation-only access across the application delivery tier.

Avi includes a dedicated Auditor role that grants Read access to view security services platform configuration, upgrades, and authentication and authorization configuration in the Avi Controller without the ability to make changes. Assessors can be assigned this role to gain visibility into the security posture of the application delivery environment without receiving any write capability.

Within the Controller administration interface, accounts can be assigned to specific roles and tenants, allowing narrowly scoped access to virtual service configurations, WAF policies, application analytics, SSL/TLS certificate profiles, health monitor definitions, analytics profiles, and application event and audit logs. Avi's extended granular role-based access control also supports sub-resource-level permissions, enabling role definitions that restrict access to specific pool sub-resources. The ability to export certificates and private keys is separately controlled through RBAC, and Avi documentation recommends restricting this capability to the fewest number of administrators possible.

Avi supports local accounts and integration with external identity providers including LDAP, SAML, TACACS+, and OAuth/OIDC, allowing organizations to provision assessor accounts through existing identity governance processes rather than creating standalone credentials. Role assignments can be scoped to specific tenants, which is useful when an assessment covers only a subset of the application delivery environment. In Kubernetes deployments using the Avi Kubernetes Operator (AKO), the ako-all-tenants-permission-controller role provides cross-tenant read access for assessors who need visibility across multiple namespaces.

This control asks whether the organization grants assessors minimum necessary access to design, development, production, inspection, and testing artifacts, and whether physical access to facilities is managed. Avi's RBAC addresses the application delivery tier. Meeting this control in full requires the organization to define the scope of each assessment, coordinate access provisioning across all relevant VCF platform components, and manage physical access to facilities. None of those dimensions fall within Avi's scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control Annex VIII Part IV (5.1)

> The manufacturer shall affix the CE marking, and, under the responsibility of the notified body referred to in point 3.1, the latter's identification number to each individual product with digital elements that satisfies the requirements set out in Part I of Annex I.

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part IV (5.2)

> The manufacturer shall draw up a written declaration of conformity for each product model and keep it at the disposal of the national authorities for 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer. The declaration of conformity shall identify the product model for which it has been drawn up. A copy of the declaration of conformity shall be made available to the relevant authorities upon request.

SCF Controls: CPL-01.5, TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control Annex VIII Part IV (6)

> The manufacturer shall, for a period ending at least 10 years after the product with digital elements has been placed on the market or for the support period, whichever is longer, keep at the disposal of the national authorities:

SCF Controls: TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

